



TEMA 5

SEGURIDAD PERIMETRAL Y

DE RED



Defendiendo y atacando el entorno de red



"S-82 NARCISO MONTURIOL" PROJECT v5.0

Por favor, informa de problemas con los materiales a redondojose@uniovi.es



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

Logo: @creative_vanesa (Instagram)



ÍNDICE



Introducción



Infraestructuras seguras básicas (Nivel 1)



Funcionamiento básico de firewalls



DNS, Proxies, CDNs y WAFs



Montando infraestructuras seguras sencillas



Infraestructuras seguras profesionales (Nivel 2)



Forwarding y Zonas: Aislamiento con firewalls



Firewalls perimetrales y vigilancia de redes (IDS/IPS)



Montando infraestructuras seguras más complejas



Infraestructuras seguras avanzadas (Nivel 3)



VLAN



Next Gen. Firewalls (NGFW) y Unified Threat Management (UTM)



Construcción de infraestructuras altamente seguras



Acceso remoto a infraestructuras

¿QUÉ VAS A APRENDER EN ESTE TEMA?

- Este tema te guiará a la hora de tomar las mejores decisiones a la hora de construir infraestructuras de máquinas para dar un servicio
 - Poniendo siempre **la seguridad en primer plano**
- *¿En función de qué?*
 - **Tus necesidades reales** de servicios (tus requisitos)
 - **Los recursos que tengas**
- Lo importante es optimizar lo que pones en marcha según tus necesidades en función de los recursos que tienes



[< Ir al Índice](#)



INTRODUCCIÓN

Entendiendo el problema de las infraestructuras y las responsabilidades que suponen



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

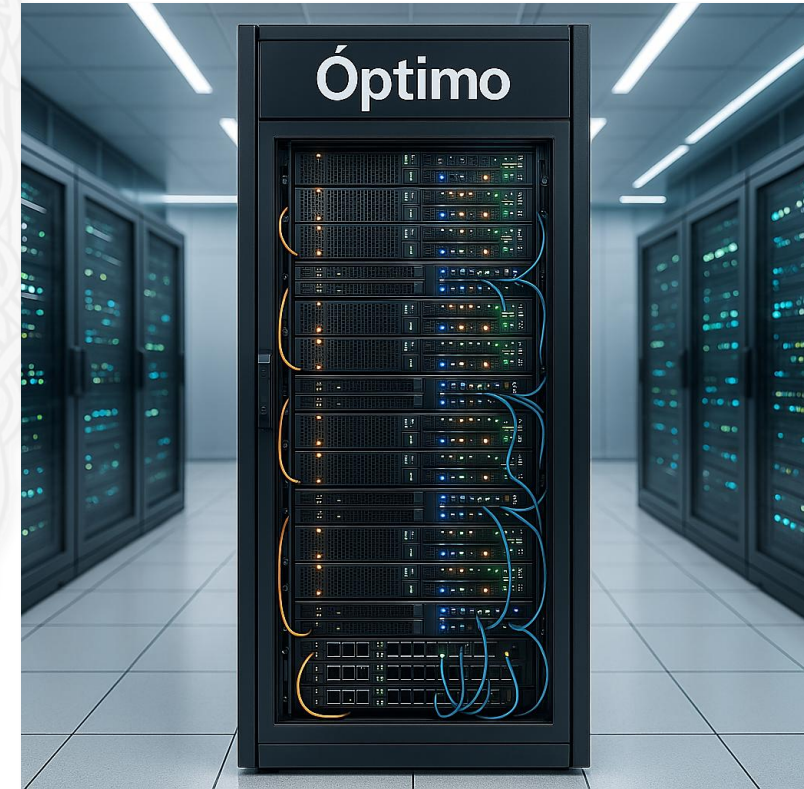
ASPECTOS COMUNES A TODAS LAS INFRAESTRUCTURAS

- Todas las infraestructuras que veremos en este tema tienen cosas en común, sin importar su nivel de complejidad
 - La mayoría se implementan a través de **MV o contenedores** ([ASR](#), L-62 “Princesa de Asturias”); *¿Por qué?*
 - Todo software en cada uno de tus nodos **debe estar adecuadamente actualizado y securizado** ([Tema 3](#))
 - Usa la **regeneración** (de MV o contenedores) como “aliado” de seguridad
 - Parar un elemento comprometido / funcionando mal de la infraestructura y reemplazarlo con uno “limpio” en un estado conocido
 - *¿Qué ventajas tiene?*
 - Esto es mucho más fácil si se crean **modelos “temáticos” de MV**
 - MV para desplegar una web, para programar, para navegar...
 - *¿Qué ventajas tiene hacer varios modelos de MV, uno para cada cosa?*



ASPECTOS COMUNES A TODAS LAS INFRAESTRUCTURAS

- **Además, en lo relativo a cada una de tus máquinas...**
 - Solo tienen **una función primaria** (preferiblemente); *¿Por qué?*
 - Ej.: **No** se junta en un mismo nodo un servidor web y una BBDD
 - **Sólo instalan el software estrictamente necesario**
 - Elimina todo **driver** o **servicio** no imprescindible (Bluetooth, USB...)
 - Tienen los **mínimos usuarios imprescindibles**
 - A ser posible, **elimina todo acceso remoto interactivo**
 - *¿Y si la máquina falla que hacemos?*
 - Ocupan solo **los recursos estrictamente necesarios** (RAM, HD...)
 - Facilita escalar la infraestructura (L-62 "Princesa de Asturias")

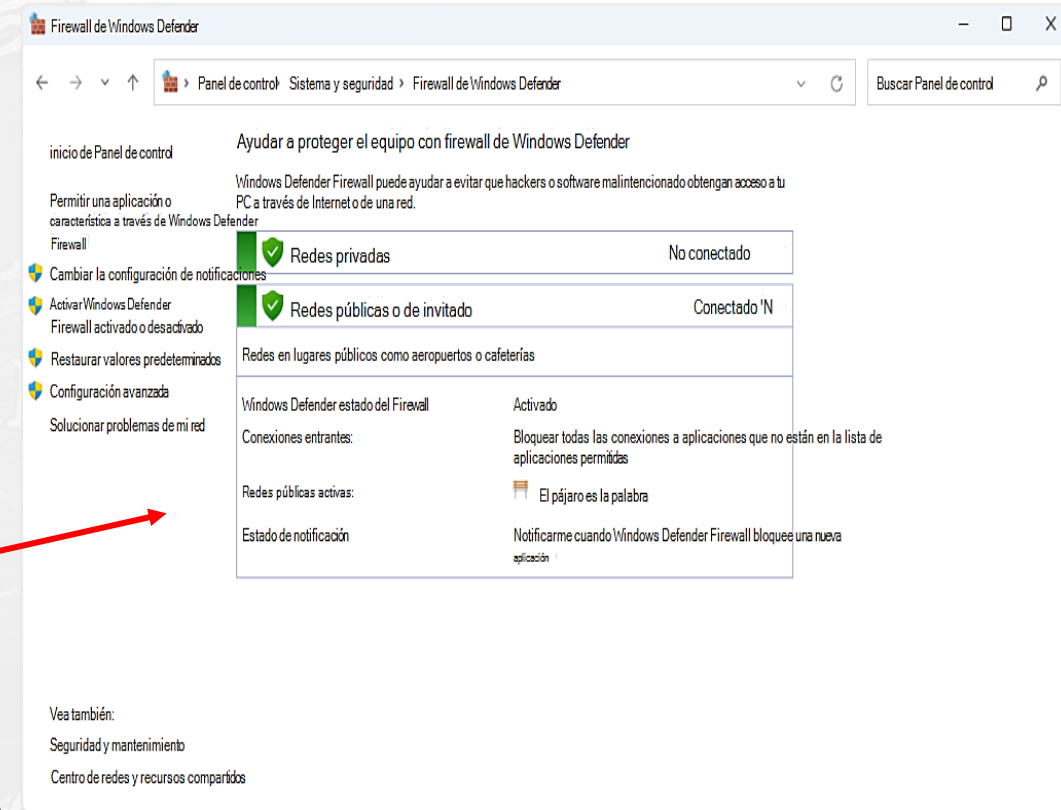


Diseñes la infraestructura que diseñes, debes saber que hay unos mínimos irrenunciables, tanto para la infraestructura como para cada uno de sus componentes

EL PROBLEMA DE LA INVERSIÓN EN SEGURIDAD DE INFRAESTRUCTURAS



- En toda infraestructura hay defensas
 - Cuya “potencia” dependerá de los recursos que puedas invertir en ellas
 - Este tema las divide en 3 niveles
 - De menos protección y coste a más
 - El firewall será nuestro elemento de protección central
- Debemos saber con qué implementarlas
 - Para el Nivel 1 bastan los firewalls de host
 - Software instalado en cada SO de cada máquina
 - Solución barata, pero de menos capacidad para procesar conexiones / paquetes y características
 - Protegen solo al host que los tiene instalados



El firewall integrado en Windows gratuitamente. Tener uno de estos activos en cada máquina es una obligación.

Fuente: <https://learn.microsoft.com/es-es/windows/security/operating-system-security/network-security/windows-firewall/tools>

EL PROBLEMA DE LA INVERSIÓN EN SEGURIDAD DE INFRAESTRUCTURAS

- El **Nivel 1** también incluye unos mínimos de seguridad en nuestros routers o Wifis

¿Cuáles son las principales configuraciones de un **router**?



- 1** **Cambia las contraseñas por defecto del router.**
Usa una para acceder a la configuración del router y otra para conectarte a la Red.
- 2** **PROTOCOLO DE SEGURIDAD**
Elige un modo de seguridad
WPA 2
- 3** **WI-FI PRINCIPAL**
Nombre del Wi-Fi (SSID) principal
MIREDESEGURA
Nombre de Red Wi-Fi visible
Clave Wi-Fi principal
Modo de seguridad
WPA2 AES
- 4** **Filtrado MAC**
Permite únicamente conectarse a la Red a tus dispositivos.
- 5** **Desactiva el acceso remoto.**
No autorices conexiones a tu router desde otra red.
- 6** **Asegura los puertos del router.**
Que no accedan a tu red cerrando los puertos que no utilices.
- 7** **Crea una red para invitados.**
Específica para conexiones puntuales.
- 8** **Actualiza el firmware del router.**
Protégelo con los parches de seguridad publicados.

Cualquier empresa tiene Wifis en alguna parte de su infraestructura. Hagas lo que hagas luego, deben guardarse unos mínimos de seguridad con ellas. Fuente: <https://www.incibe.es/ciudadania/formacion/infografias/principales-configuraciones-del-router>

EL PROBLEMA DE LA INVERSIÓN EN SEGURIDAD DE INFRAESTRUCTURAS



- **Nivel 2** y **Nivel 3** pueden implementarse con **firewalls híbridos**, como...
 - **2A: Hardware compacto** con funciones de firewall+
 - Routers comerciales con funciones avanzadas
 - Pequeños router/firewalls portátiles
 - **2B: Hardware de PC estándar** ejecutando firewalls software
 - Una máquina física o virtual con SSOO que son firewalls avanzados
 - Ej.: Linux personalizados a los que se les elimina casi todo lo que no es exclusivamente funciones de un firewall
 - Ejs.: OPNSense, IPFire, pfSense...
 - Ambos con **una interfaz web** para manejar sus (muchas) opciones
- **Son un compromiso entre capacidades y coste**
 - Cuentan con **funciones avanzadas**: soporte de VPNs, IDS/IPS, logs, aislamiento entre distintas redes...



Un router/firewall portátil. Fuente:

https://www.amazon.es/dp/B0B2J7WSDK/ref=sspa_dk_hqp_detail_aax_0



PC compacto que puede hacer de firewall híbrido, con dos tarjetas de red para que sea más sencillo. Fuente:

<https://www.amazon.es/NiPoGi-Ordenadores-Sobremesa-Computadora-Educaci%C3%B3n/dp/B0BY25NQGP/>

EL PROBLEMA DE LA INVERSIÓN EN SEGURIDAD DE INFRAESTRUCTURAS



- Cuando el n° de máquinas y la complejidad de la infraestructura es mayor, los híbridos quedan cortos
- Entonces debemos usar firewalls hardware para el **Nivel 3**
 - Hardware que ha sido **diseñado expresamente para ser un firewall**
 - Maximizando el procesamiento de conexiones / paquetes
 - Con **software de control específico** enfocado a “exprimir” su uso
 - Con prestaciones (**muy**) **avanzadas**
 - VPN, IDS/IPS, aislamiento, reglas avanzadas...
 - Normalmente con tomas de red de **velocidades superiores**
 - Es la opción más cara...pero la **más potente**
 - *¿Y cuál será la mejor en tu caso (qué nivel necesitas)?*



Firewall hardware. Fíjate las tomas de red que tiene, que permiten (directamente o con switches intermedios) atender eficientemente a muchas más máquinas. Fuente: <https://www.amazon.es/Rackmount-Firewall-Hardware-OPNsense-Appliance/dp/B09H6FFPFH>

[< Ir al Índice](#)



INFRAESTRUCTURAS SEGURAS BÁSICAS (NIVEL 1)

Se pueden construir infraestructuras seguras incluso con bajo presupuesto



 [Firewalls >](#)

 [Proxy, CDN, WAF >](#)

 [Construcción inf. >](#)



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

¿QUÉ VAS A APRENDER EN ESTE BLOQUE?

- Esta sección te explica conceptos de redes que necesitas dominar para definir mejor tus infraestructuras seguras
 - **La importancia del DNS** para decidir a dónde se puede acceder y a dónde no
 - **Los firewalls** como “muro de acceso” a servicios y **cómo funcionan internamente**
 - Hemos visto los tipos, pero para decidir cuál usar necesitamos profundizar más en ellos
 - En esta sección te explicaremos todo lo necesario para que los entiendas
 - **Elementos de protección imprescindibles**, como proxies, CDNs y WAFs
 - Con todo ello, cómo **montar una infraestructura razonablemente segura** a un coste también razonable 😊



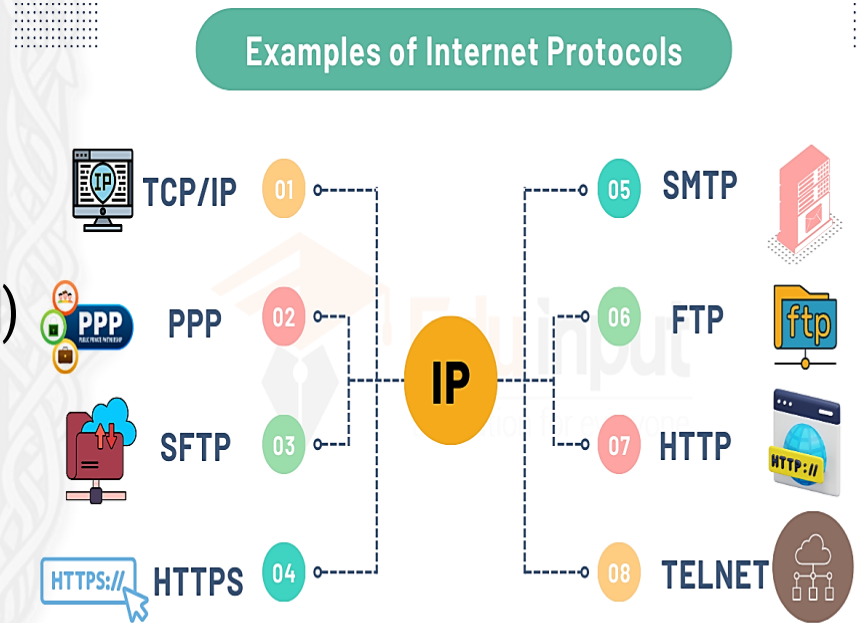


Funcionamiento básico de firewalls

Puertos, servicios, protocolos, estado, conexiones y reglas



- Definen las reglas de comunicación entre servicios
- Hay muchos: TCP, IP, UDP, FTP, HTTP, SMTP...
 - Cada uno define sus propias reglas, **en documentos RFC**
 - Ejs.: IP (Internet Protocol) y TCP (Transmission Control Protocol)
- Debes tener en cuenta una máxima: **“Protocolo prohibido, problema suprimido”**
 - **Prohíbe expresamente todo protocolo que no use ninguno de tus servicios**
 - Los firewalls que veremos son los encargados de ello
 - Otra forma de principio de minimización: **No soportes nada que no uses, en ningún caso ni contexto**



Cada protocolo define las reglas de comunicación entre software de distinto tipo que los usa. Piensa en ellos como el idioma que hablan entre sí los servicios. Fuente: <https://engage.primeone.global/essential-network-protocols-you-need-to-know/>

¿QUÉ DEBO TENER CLARO RESPECTO A LOS FIREWALLS?



- Cualquier dispositivo para los usuarios externos es una lista de puertos con servicios escuchando (**Tema 1**)
- La política de acceso (**Tema 3**) a máquinas / servicios debe ser
 - **Reducir al máximo** quién puede acceder a cada servicio
 - **Prohibir todo acceso** si se detectan actividades sospechosas
 - Aunque sea de orígenes autorizados
- Son los firewalls los que pueden hacer todo esto
 - Tanto a máquinas individuales como a redes (**máscaras CIDR**)
 - Bloqueando conexiones entrantes y **salientes**
 - **Iniciadas por un programa dentro de la máquina**, no respuestas a conexiones entrantes ya permitidas (esas se responden siempre)

```
C:\net\nmap>nmap -sUC -O -T4 scanme.nmap.org
Starting Nmap 4.68 ( http://nmap.org ) at 2008-07-13 23:23 Pacific
Interesting ports on scanme.nmap.org (64.13.134.52):
Not shown: 1709 filtered ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 4.3 (protocol 2.0)
25/tcp    closed smtp
53/tcp    open  domain   ISC BIND 9.3.4
70/tcp    closed gopher
80/tcp    open  http     Apache httpd 2.2.2 ((Fedora))
|_ HTML title: Go ahead and ScanMe!
113/tcp   closed auth
Device type: general purpose
Running: Linux 2.6.X
OS details: Linux 2.6.20-1 (Fedora Core 5)
Uptime: 11.487 days (since Wed Jul 02 11:42:43 2008)

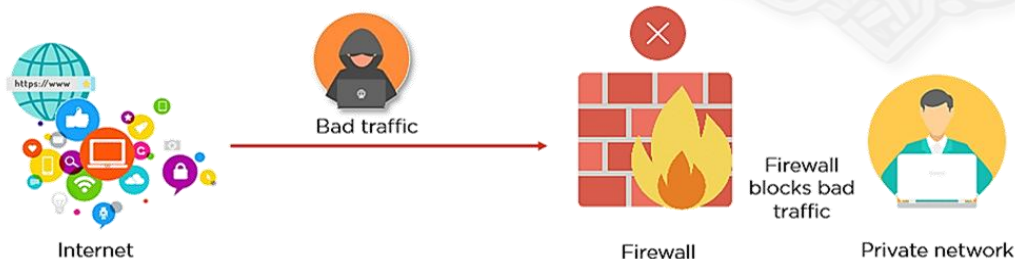
OS and Service detection performed. Please report any incorrect
//nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 27.516 seconds
```

Puertos, servicios y versiones averiguados con Nmap. (Tema 6). Es válido para PCs, móviles, IoT, equipamiento industrial...pero no debería poder hacer esto si no soy una máquina expresamente autorizada... Fuente:

<https://nmap.org/book/inst-windows.html>

¿QUÉ DEBO ENTENDER, POR TANTO, COMO FIREWALL?

- Elemento de **protección de redes** diseñado para bloquear acceso no autorizado
 - Parte de un **sistema** (software) o de una **red** (hardware + software especializado)
 - También podría tener funciones de log de conexiones, auditoría, detección/prevencción de intrusos...
 - Capaz de **controlar puertos, servicios, protocolos y conexiones** permitidas y no permitidas
- Funcionan con **reglas configurables** que controlan el tráfico
 - Su política **por defecto** suele ser **firewall -> red: permitido, firewall <- red: bloqueado**
- Hay distintos tipos de firewalls en función de...
 - Sus **capacidades de procesamiento** (software o hardware, vistos al inicio del tema)
 - Su **funcionamiento** a la hora de procesar las conexiones (lo veremos ahora)
 - El **área de red** que permiten controlar (perimetrales o no, **Nivel 2**)



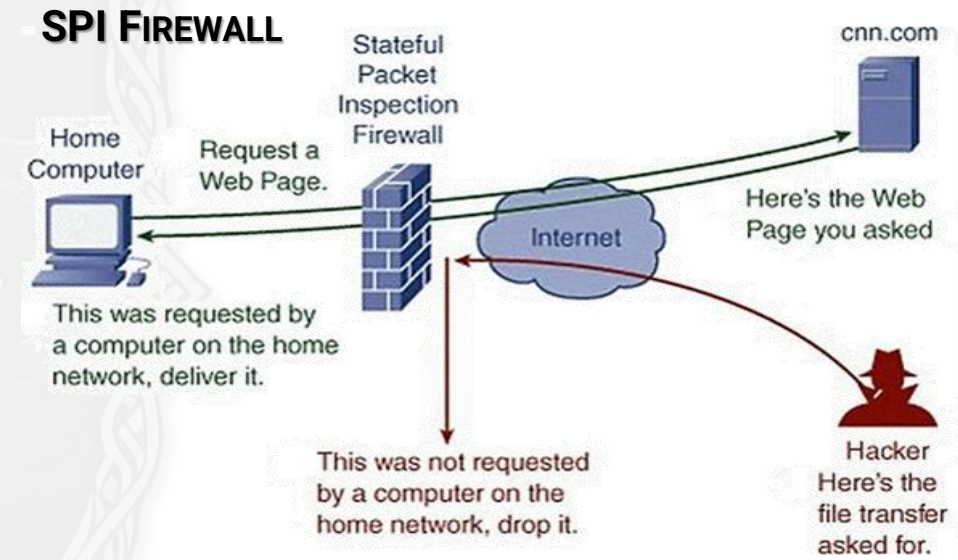
Hay muchos tipos de firewall, pero todos tienen una función primaria de protección y bloqueo de tráfico no deseado.

Fuente: <https://www.simplilearn.com/tutorials/cyber-security-tutorial/what-is-firewall>

FIREWALLS STATEFUL PACKET INSPECTION (SPI)



- Tienen una tabla con información de todas sus conexiones abiertas
 - Direcciones IP y puertos de origen y destino
 - El protocolo usado (que depende del servicio, como vimos)
 - Su estado actual (Ej.: iniciando, establecida, finalizando)
- Toman decisiones **basadas en reglas**
 - El firewall compara la **información de la cabecera** de cada paquete con su tabla de conexiones
 - Y determina **si es parte de una conexión ya establecida**
 - Si lo es, entonces el paquete se acepta **sin más análisis**
 - De lo contrario, es un intento de conexión nueva, y decide si la admite o no con **el conjunto de reglas que tiene definido**
- La mayoría de firewalls más usados son SPI
 - El de Windows, iptables, nftables, IPSet, FirewallD, ConfigServer, pf, Firewalls comerciales para endpoints...



Si el tráfico pertenece a una conexión permitida, se permite automáticamente. No tienes que hacer reglas para tráfico entrante y su respuesta saliente, por ejemplo, con una regla para todo vale. Fuente: <https://flylib.com/books/en/2.282.1.10/1/>

ESTRUCTURA GENERAL DE LAS REGLAS DE UN FIREWALL

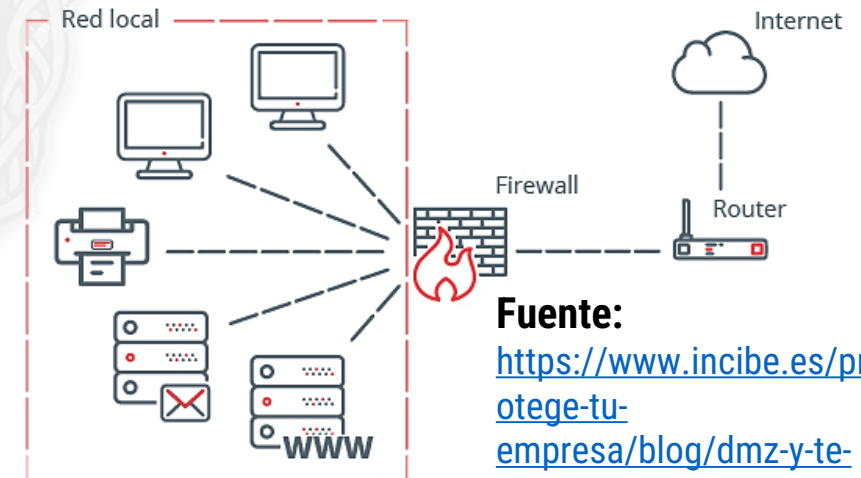
● Su estructura podría variar según el firewall

- **Acción:** Qué hacer con el tráfico que encaja con la regla
 - Permitir (**ALLOW**), rechazar (**REJECT**) o descartar (**DROP**)
- **Dirección:** Si se aplica al tráfico **entrante** (Inbound/**INPUT**) o **saliente** (Outbound/**OUTPUT**)
- **Origen:** La IP o rango de IPs de donde proviene el tráfico
- **Destino:** La IP o rango de IPs a la que se dirige el tráfico
- **Protocolo:** El protocolo de red (TCP, UDP, ICMP, etc.)
- **Puerto:** El puerto de origen o destino
 - Para protocolos que los usen, como TCP/UDP
- **Interfaz:** La interfaz de red por la que entra o sale el tráfico
 - Piensa que muchas máquinas tienen varias

Status: active

To	Action	From
--	-----	----
22	ALLOW	Anywhere
80	ALLOW	Anywhere
Apache	ALLOW	Anywhere
22 (v6)	ALLOW	Anywhere (v6)
80 (v6)	ALLOW	Anywhere (v6)
Apache (v6)	ALLOW	Anywhere (v6)

Se permiten conexiones desde cualquier lugar utilizando IPv4 o IPv6, pero solo a los puertos 22 (**ssh**) o 80 (**http**)



Fuente:
<https://www.incibe.es/pr otege-tu-empresa/blog/dmz-y-te-puede-ayudar-proteger-tu-empresa>

ESTRUCTURA GENERAL DE LAS REGLAS DE UN FIREWALL: EJEMPLOS

● Ejemplos simplificados (IPs, puerto, protocolo)

1. "La IP 192.168.3.10 solo puede acceder a este servidor cuando se conecta al puerto 22 mediante el protocolo TCP": **Solo esa máquina puede conectarse al servidor a través de SSH (22)**
2. "El tráfico TCP entre 192.168.10.0/24 y 192.168.25.0/24 sólo se permite a través del puerto 3306": **Las conexiones MySQL (puerto 3306) solo son posibles entre máquinas del rango de IPs 192.168.10.X a máquinas del rango de IPs 192.168.25.X**
3. "El tráfico TCP/UDP desde cualquier dirección IP solo se permite a la dirección 192.168.59.15, puerto 443": **El tráfico de Internet sólo puede conectarse a ese servidor web mediante HTTPs (puerto 443)**

Las reglas 1 y 3 son reglas típicas de firewall de host

La regla 2 es típica de firewall perimetral (vistos luego)

Fuente:

<https://campus.barracuda.com/product/cloudgenfirewall/doc/79463228/firewall-rule-list-interface-and-icons>

Forwarding Firewall - Rules								
Main Rules								
	Action	Name	Features	Service	Source	Destination	Application Policy	User
0	→ Pass Dynamic NAT	BOX-BARRACUDA-CUD...		Ref: ScreenConnect TCP 443, TCP 8040, TCP ...	Ref: Trusted LAN , Ref: WI...	Ref: 10.17.94.0/24	connect.barracuda.com	Any
1	→ Block	BlockATDQuarantine		Ref: Any ALLIP *, ECHO , TCP *, TC...	Ref: ATD Quarantine	Ref: Any 0.0.0.0/0	N.A.	Any
2	→ Pass Original Source IP	BOX-EVAL-MODE-BRIDGE		Ref: Any ALLIP *, ECHO , TCP *, TC...	Ref: Eval Mode Bridged Ports 0.0.0.0/0 dev MGMT, 0.0.0...	Ref: Eval Mode Bridged Ports 0.0.0.0/0 dev MGMT, 0.0.0...	AppControl, URL.FI	Any
3	↔ App Redirect 192.168.200.200	BOX-SETUP-MGMT-ACC...		Ref: NGF-MGMT-BOX ECHO , TCP 22, TCP 807...	Ref: Private IPv4 Addresses 10.0.0.0/8, 172.16.0.0/12, ...	Ref: DHCP1 Local IP	No AppControl	Any
4	↔ App Redirect 127.0.0.1:53	BOX-LOCALDNSCACHE		UDP 53 , TCP 53	Ref: Trusted LAN 10.17.94.0/24	Ref: Any 0.0.0.0/0	AppControl, URL.FI	Any
5	→ Pass Dynamic NAT	BOX-LAN-2-INTERNET		Ref: Any ALLIP *, ECHO , TCP *, TC...	Ref: Trusted LAN 10.17.94.0/24	Ref: Internet 0.0.0.0/0, NOT 10.0.0.0/8, ...	AppControl, URL.FI	Any
6	→ Pass Original Source IP	BOX-LAN-2-LAN		Ref: Any ALLIP *, ECHO , TCP *, TC...	Ref: Trusted LAN 10.17.94.0/24	Ref: Trusted LAN 10.17.94.0/24	AppControl, URL.FI	Any
7	↔ Pass Original Source IP	BOX-LAN-2-VPN-SITE		Ref: Any ALLIP *, ECHO , TCP *, TC...	Ref: Trusted LAN 10.17.94.0/24	Ref: VPN-Networks 0.0.0.0/0 dev vpn0	AppControl, URL.FI	Any
8	→ Pass Original Source IP	BOX-VPN-SITE-2-SITE		Ref: Any ALLIP *, ECHO , TCP *, TC...	Ref: VPN-Local-Networks 0.0.0.0/0	Ref: VPN-Remote-Networks 0.0.0.0/0 dev vpn0	AppControl, URL.FI	Any
9	→ Pass Dynamic NAT	BOX-VPNCLIENTS-2-LAN		Ref: Any ALLIP *, ECHO , TCP *, TC...	Ref: Any 0.0.0.0/0	Ref: Trusted LAN 10.17.94.0/24	AppControl, URL.FI	Any



DNS, Proxies, CDNs y WAFs

Escudos imprescindibles hasta para las infraestructuras más básicas



¿POR QUÉ LOS DNS SON IMPORTANTES PARA LA SEGURIDAD?



- Te dan el control total de a dónde se puede navegar/acceder y a dónde no
 - Se ven en **ASR** como “traductores” de nombre DNS <-> IP (Ej.: **uniovi.es** <-> **156.35.94.10**)
- *¿Qué pasa si este “traductor” supiera de antemano qué dominios son maliciosos?*
- Las opciones para usar un DNS con seguridad integrada son
 - **Contratarlo a un tercero:** Es la opción más cómoda y automática, pero puede tener un coste
 - Un buen ejemplo es NextDNS: <https://nextdns.io/>
 - Hay más: AdGuard, Quad9, CleanBrowsing...
 - **Montar tu propio servidor DNS** de esta clase (Ej.: PiHole (<https://pi-hole.net/>))
 - Pero debes mantenerlo y actualizar sus listas de bloqueo...

Malware Blocking Only

Primary DNS: 1.1.1.2

Secondary DNS: 1.0.0.2

Malware and Adult Content

Primary DNS: 1.1.1.3

Secondary DNS: 1.0.0.3

For IPv6 use:

Malware Blocking Only

Primary DNS: 2606:4700:4700::1112

Secondary DNS: 2606:4700:4700::1002

Malware and Adult Content

Primary DNS: 2606:4700:4700::1113

Secondary DNS: 2606:4700:4700::1003

DNS seguros públicos conocidos que filtrarían ciertas peticiones maliciosas originadas en nuestra infraestructura. NextDNS es mejor opción

¿QUÉ ES UN PROXY?

- **Servidor o software intermediario** entre origen y destino
 - A no conecta con B, sino con el proxy P
 - P luego **reenvía** al destino final B la petición en nombre de A
 - La respuesta de B para A pasa también por P antes de llegar a A
- **Sus funciones principales son**
 - **Mejorar la seguridad:** Filtrar tráfico malicioso, bloquear el acceso a sitios peligrosos, ocultar la dirección IP del usuario (por tracking)...
 - *¿Qué instalarías en ellos del Tema 4?*
 - **Dar más privacidad y el anonimato; ¿Cómo?**
 - **Filtrar contenido; ¿Cómo?**
 - **Mejorar el rendimiento; ¿Cómo?**
 - **Evitar restricciones geográficas; ¿Cómo?**



Los proxies hacen de “recaderos” 😊, y eso conlleva bastantes ventajas:

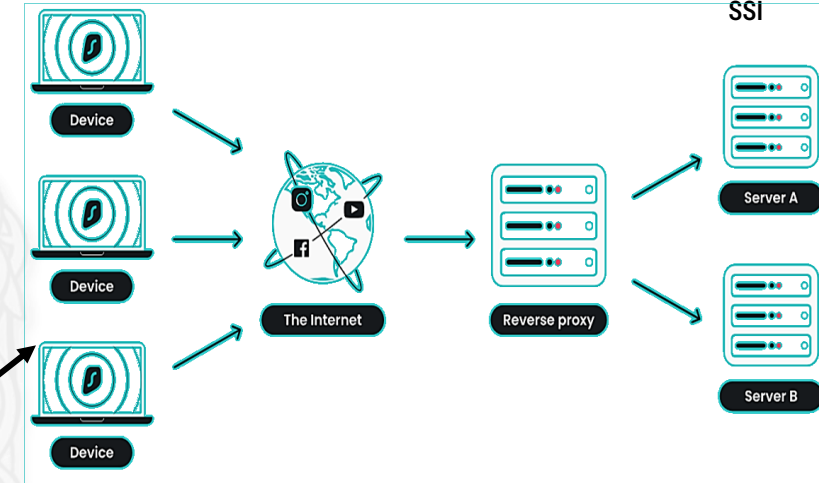
<https://brightdata.es/blog/101-proxy/how-to-find-proxy-server-address>

ALGUNOS TIPOS DE PROXY

● Entre los múltiples tipos de proxy podemos destacar

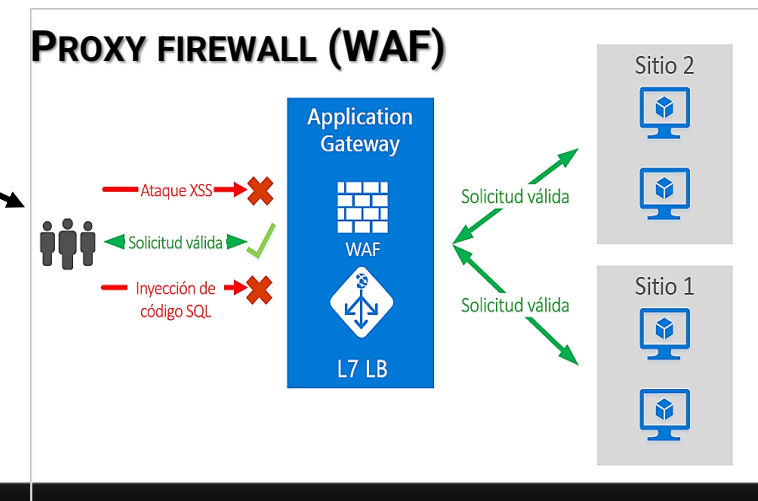
- **Reverse proxy:** Se sitúa delante de uno o varios servidores
 - Recibe las solicitudes de los clientes “de fuera”
 - Y las dirige al servidor apropiado “de dentro” según la petición
 - Permite **equilibrio de carga, seguridad y optimización**
- **Proxy o Application firewall:** ¡El WAF que vimos en el **Tema 4**!
 - Un SPI estándar solo puede controlar las solicitudes entre hosts (IPs) que le llegan
 - ¡No entiende de usuarios!
 - No usa el contenido de los paquetes para tomar decisiones
 - Un proxy firewall sí lo hace: Filtra **en la capa de aplicación**

Fuente: <https://learn.microsoft.com/es-es/azure/web-application-firewall/ag/ag-overview>



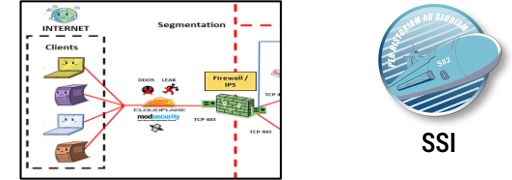
Esquema clásico de un reverse proxy. Detrás de él ningún cliente sabe exactamente qué hay, y es el que “da la cara” por todo lo que tiene “detrás”. Fuente:

<https://surfshark.com/blog/proxy-server>



CONTENT DELIVERY NETWORK (CDN)

- **Servicio basado en la nube que proporciona una capa de seguridad adicional**
 - Las solicitudes a tu infraestructura se filtran en la red de CDNs como CloudFlare o TransparentEdge
 - Es decir, las CDNs te hacen de proxy ante tus usuarios
- **Da características de seguridad avanzadas. Ej.:**
 - **Protección anti DDoS** completa y robusta
 - Garantizar **conexiones HTTPS** adecuadas
 - **WAF**
- **Incluso contratando sólo servicios gratuitos obtenemos un beneficio de seguridad**
 - *¿Qué pasa con la liga de futbol Española?*



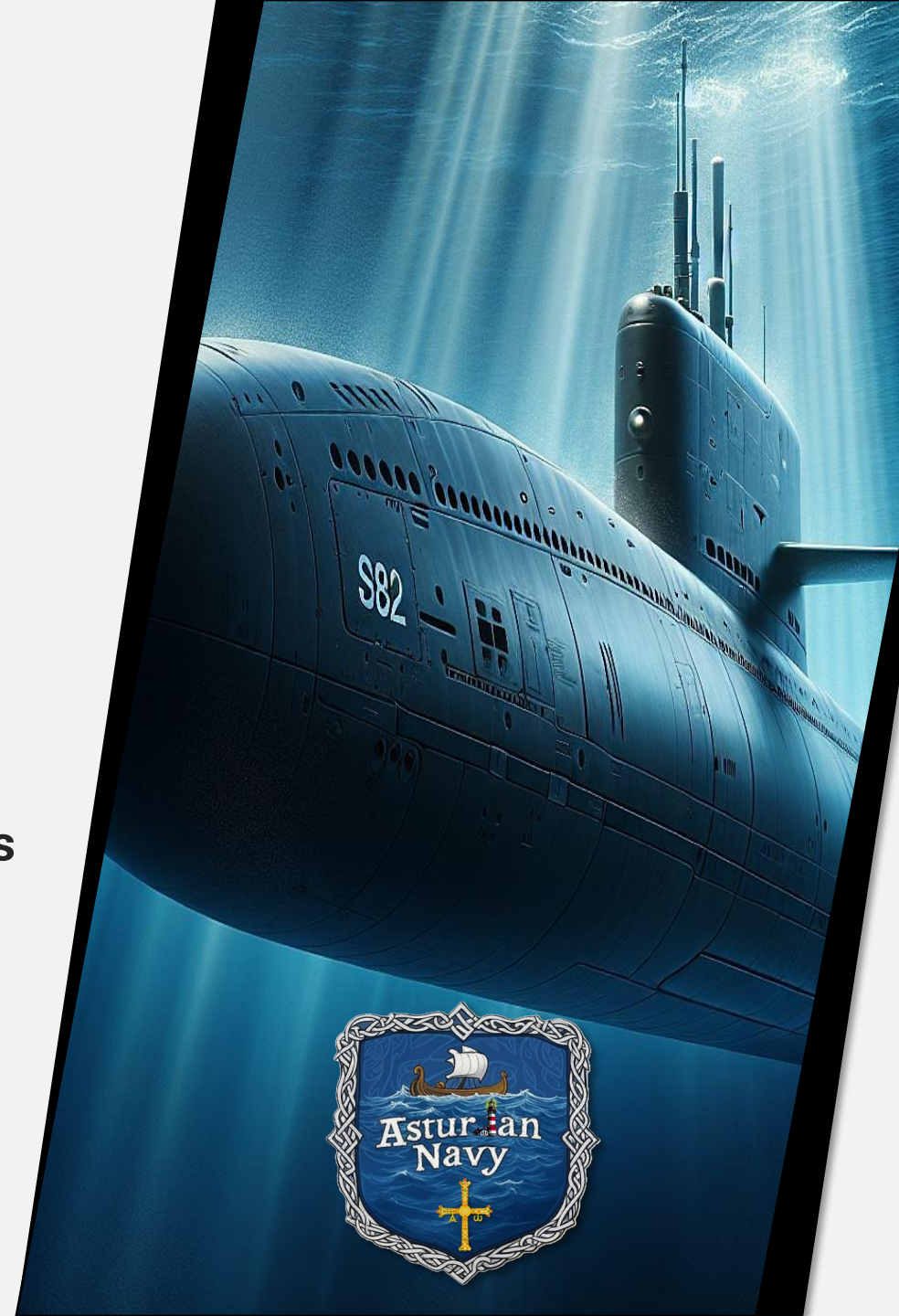
	Gratuito	Pro	Business	Enterprise
	0 USD/mes Los complementos se facturarán mensualmente	20 USD/mes Facturación anual o 25 USD facturación mensual	200 USD/mes Facturación anual o 250 USD facturación mensual	Personalizado Facturación anual
	Añadir sitio web	Empezar	Empezar	Consultar con un experto
DNS rápido y fácil de usar	① ✓	✓	✓	✓
Protección contra DDoS ilimitada	① ✓	✓	✓	✓
CDN	① ✓	✓	✓	✓
Certificado Universal SSL	① ✓	✓	✓	✓
Conjunto de reglas administradas gratis	① ✓	✓	✓	✓
Firewall de aplicaciones web (WAF)	① ✓	✓	✓	✓
Optimización de imagen sin pérdida	① ✗	✓	✓	✓
Accelerated Mobile Pages (AMP)	① ✗	✓	✓	✓
Conformidad con PCI DSS 3.2	① ✗	✗	✓	✓
SLA de tiempo activo	✗	✗	100 %	100 %

Esto es Cloudflare. No tener una CDN o un WAF por temas económicos ya no es excusa. Eso sí, mira bien los términos y condiciones, las políticas de uso aceptable y las condiciones, para evitar cargos indeseados



Montando infraestructuras seguras sencillas

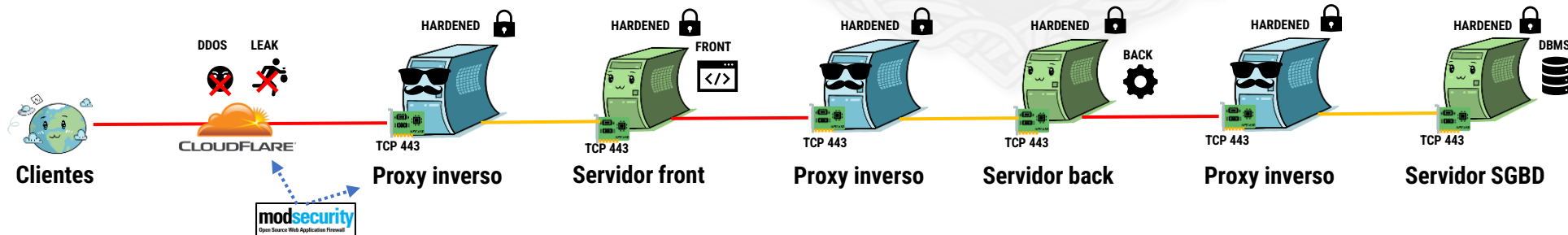
Aún con poco presupuesto se pueden lograr cosas resistentes



-

MONTANDO INFRAESTRUCTURAS CON BAJO PRESUPUESTO

- **DetachedSimple:** front y back + SGBD separados por un proxy inverso
 - CDN/WAF – proxy/WAF – Front – proxy – Back + SGBD (eligiendo WAF en CDN o en proxy)
 - El front dirige peticiones al **back** a través del **proxy**
 - El **proxy** debe saber a qué máquina del **back** dirigir cada petición del **front** (por su configuración)
 - **Mejora el aislamiento e independencia entre capas:** más seguridad y resiliencia
 - Los cambios en el **back** son independientes del **front**
 - *¿Si cambias la tecnología del back, el front es consciente de ello?*
 - Los demás aspectos de cada nodo igual que **AllIn1/AllIn1RP**
- **DetachedFull:** Misma aproximación, pero con dos proxies inversos
 - CDN/WAF – proxy/WAF – Front – proxy – Back – proxy – SGBD (eligiendo WAF en CDN o en proxy)
 - Especialmente útil si la fuente de datos puede cambiar o es dinámica



¿Cuántas "capas"?
(DetachedSimple, DetachedFull):
Depende de tus recursos y de
cuánta independencia necesites
en cada una de ellas

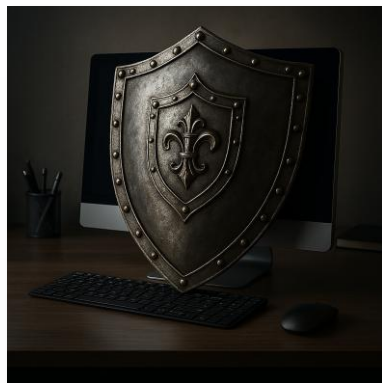
¿CREES QUE LO HAS ENTENDIDO TODO? ¡AUTOEVALÚATE!



● Asegúrate de haber entendido lo siguiente

- *La protección que te puede brindar contar con un DNS seguro y cómo disponer de uno*
- *El concepto de protocolo de red*
- *El concepto básico de firewall y la diferencia entre los software, híbridos y hardware*
- *Que cualquier firewall funciona a base de reglas, y lo que permiten modelar éstas exactamente*
- *Cómo funciona un firewall SPI y la diferencia con un firewall PF*
- *El concepto de proxy y su relación con un WAF*
- *El concepto de CDN y su relación con un proxy y un WAF*
- *Cuál es el propósito principal de un proxy firewall / WAF, y por qué actúa a nivel de aplicación*
 - *Y que estos WAF necesitan reglas y de dónde poder sacarlas*
- *Posibles infraestructuras seguras sencillas apoyadas en el concepto de firewalls de host (y su correcta configuración), WAFs, CDNs y proxies*

< Ir al Índice



↕ Zonas >

🏰 Perimetrales >

🛡️ Construcción inf. >

🛡️ 🛡️ INFRAESTRUCTURAS SEGURAS PROFESIONALES (NIVEL 2)

Cuando la importancia de los activos aumenta, también debe hacerlo la seguridad de su infraestructura



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

¿QUÉ VAS A APRENDER EN ESTE BLOQUE?

- Esta sección profundizará en los conceptos de redes que debes entender para mejorar la seguridad de las infraestructuras que diseñes
 - El concepto de **reenvío de puertos** como una forma de aislar redes entre ellas
 - Qué es una **zona de un firewall** y cómo usarla para separar máquinas en diferentes redes
 - Cómo combinar los conceptos anteriores
 - El propósito de una zona especial denominada **DMZ**
 - El concepto de **firewall perimetral** y su utilidad
 - Cómo un firewall puede llevar asociadas funciones de **detección y prevención de intrusiones**
 - La relación del concepto de **DPI** con la detección de intrusiones
 - **Infraestructuras seguras** construidas con estos elementos más avanzados





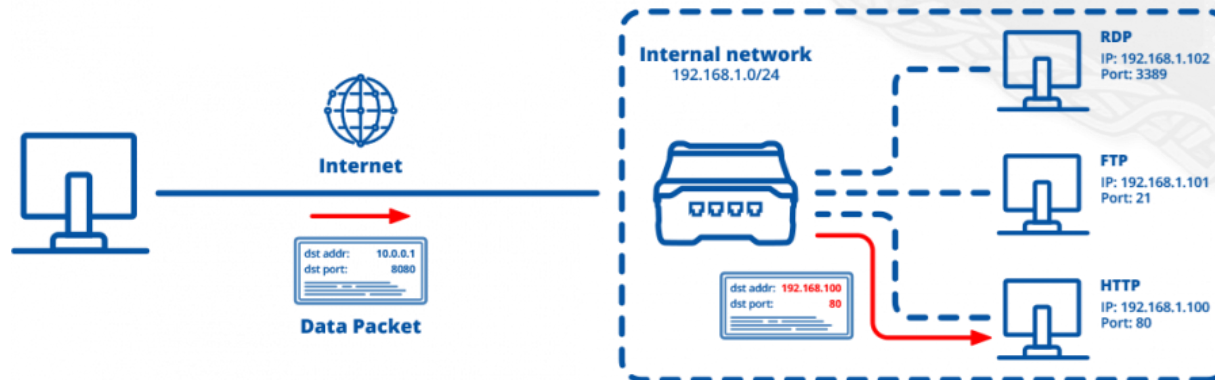
Forwarding y Zonas: Aislamiento con firewalls

Cuando los firewalls hacen de intermediarios



PORT FORWARDING (REENVÍO DE PUERTOS)

- **Técnica que permite redirigir el tráfico que llega a un puerto de una IP**
 - Normalmente hacia otro puerto de otra IP, de manera transparente y automática
 - Las IPs destino suelen estar **entre dos redes distintas**
 - Es similar a un proxy, pero a **más bajo nivel** (paquetes de red y puertos)
 - Función extra de muchos firewalls, añadiendo un **extra de filtrado / seguridad**
 - **También se implementa con reglas**
- *¿Para qué se usa esta técnica?*



El firewall recibe todas las peticiones externas, y sus reglas determinan a qué servidores internos (e invisibles a los clientes) se remiten. Como en un proxy, nadie “de fuera” sabe nada de lo que hay “dentro”. Fuente: https://wiki.teltonika-networks.com/view/Port_Forwarding

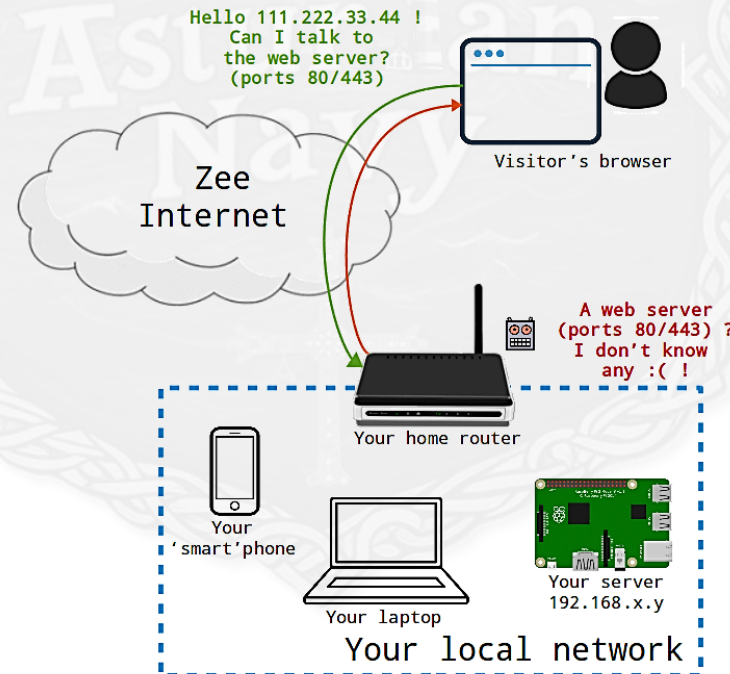
PORT FORWARDING (REENVÍO DE PUERTOS)

● En tu router de casa sueles tener una opción de “abrir un puerto en el router” o “reenvío de puertos”

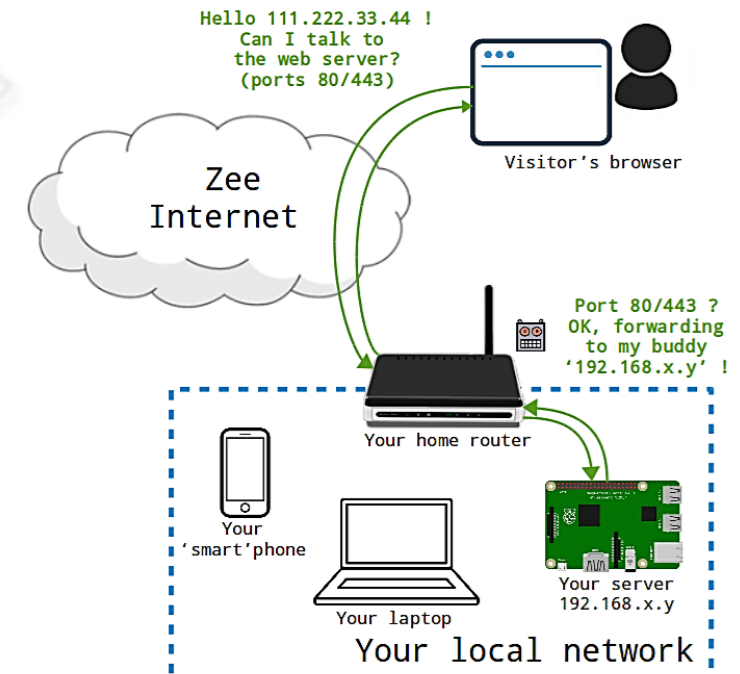
- Al abrirlo, el GUI del router te pide una dirección de tu red local y un puerto de destino
- Es decir, es un port forwarding “de libro” 😊
- Funciona, salvo que tu ISP te haya puesto bajo CG-NAT. *¿Qué es?*

Eso se hace tanto en entornos de oficina como en hogares, siempre que el router tenga una IP pública válida accesible por tus clientes, lo cual no ocurre para Internet si tu ISP usa **CG-NAT**. En ese caso **no es posible** abrir puertos. Fuente:

<https://finevpn.org/glossary/port-forwarding/>



Without port-forwarding configured

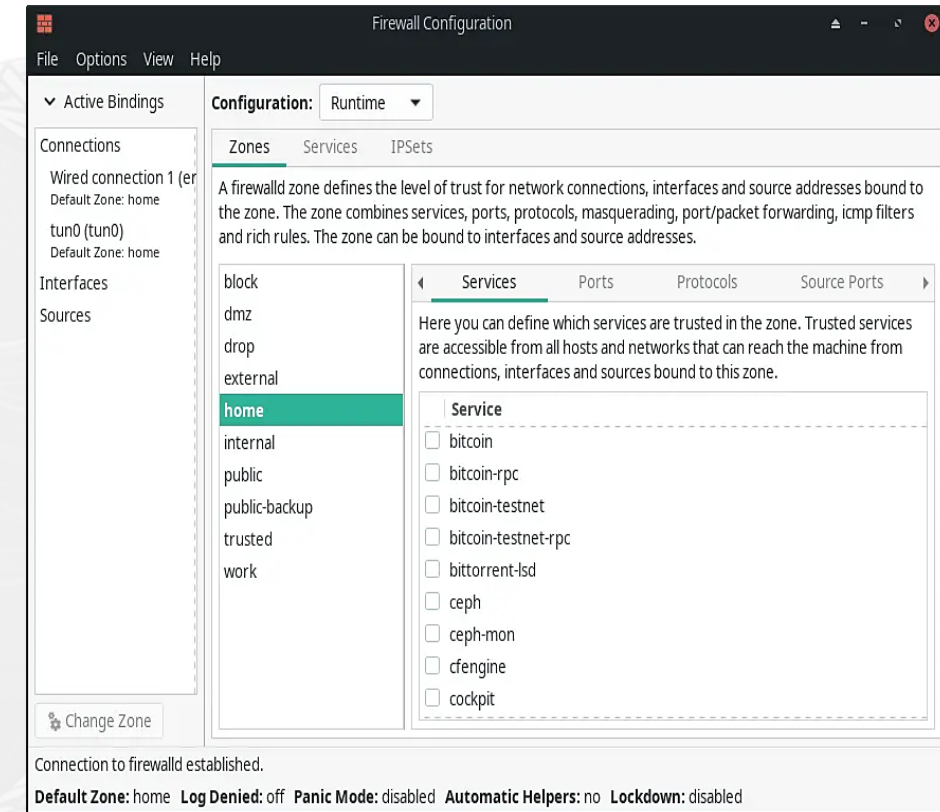


With port-forwarding configured

ZONAS DE UN FIREWALL



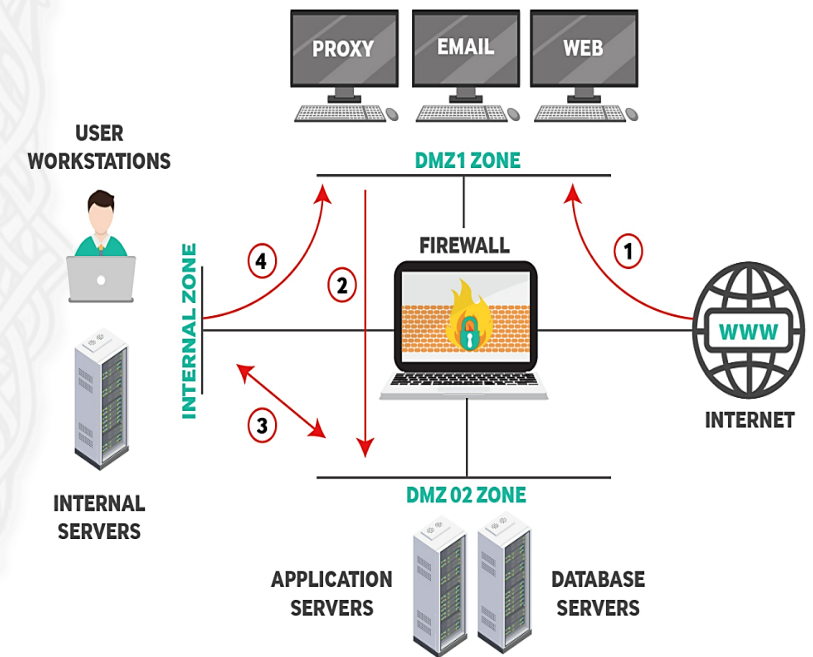
- Algunos firewalls incorporan el concepto de zona
 - Agrupación de tarjetas de red en 1 sola entidad de gestión
 - Divisiones lógicas de una red
 - Si defines una regla para una zona, la defines para **todas las tarjetas de red** que pertenezcan a ella
 - *¿Qué ventaja tienen las zonas? ¿Qué necesitas para definirlas correctamente y que funcionen?*
 - Los firewalls que las soportan permiten definir reglas de acceso y control de tráfico **entre nombres de zonas**
 - Simplifica la administración y mejora el nivel de seguridad
 - Ej.: “Entre ‘frontend’ y ‘backend’ solo se permite tráfico HTTPs al puerto 3345”



Al principio resulta difícil de entender, pero ¿Te has parado a pensar lo difícil que es configurar una máquina con muchas interfaces de red?. Las zonas de firewalld, por ejemplo, te lo facilitan. Fuente:
<https://www.inmotionhosting.com/support/security/how-to-configure-firewalld-basic-commands/>

ZONAS DE UN FIREWALL

- Muchos firewalls tienen zonas preconfiguradas, tú decides qué tarjetas metes en cada una
 - Ejs.: **LAN** (red de tu casa), **WAN** (red externa a la de tu casa), **WLAN** (tu Wifi), **Invitados...** y **DMZ** (siguiente hoja)
- El propósito de usar zonas en un firewall es
 - **Dividir la red en segmentos aislados** para reducir la superficie de ataque
 - **Agrupar interfaces con requisitos de seguridad similares:** Reglas uniformes y más simples a todas las zonas
 - **Gestión de riesgos:** Al separar áreas de diferente confianza
 - Se pueden aplicar políticas de seguridad más estrictas a las zonas de mayor riesgo (o que contienen información sensible)
 - Ejs.: “Permitir solo tráfico web saliente de la LAN a la zona WAN”, “Permitir solo conexiones entrantes al servidor web en la zona DMZ desde la zona WAN”



Partir tu red en zonas puede ayudarte a definir mejor su seguridad. No desprecies esta opción si tienes un firewall que te la ofrece. Fuente:
<https://www.titanhq.com/blog/best-firewall-security-zone-segmentation-for-optimal-network-security/>

DEMILITARIZED ZONE O DMZ

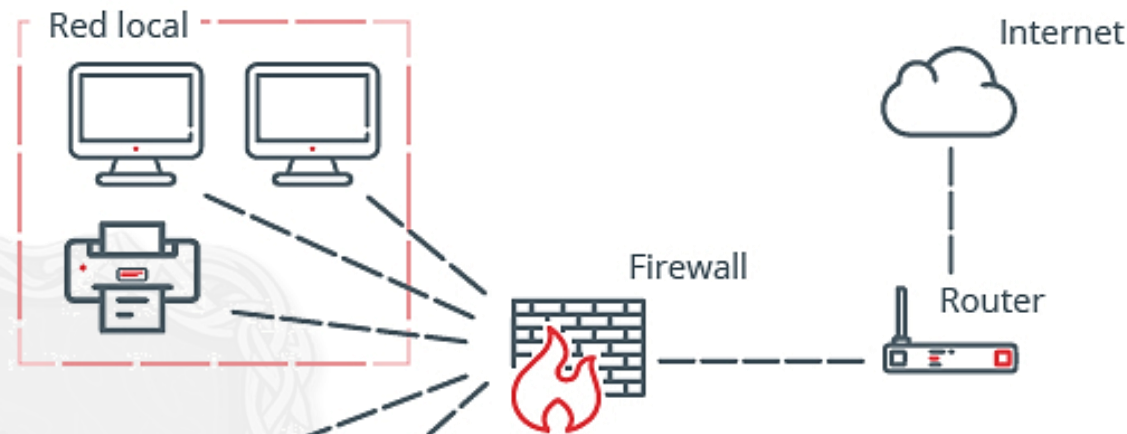


- **Zona especial pensada para contener todos los recursos accesibles desde Internet**

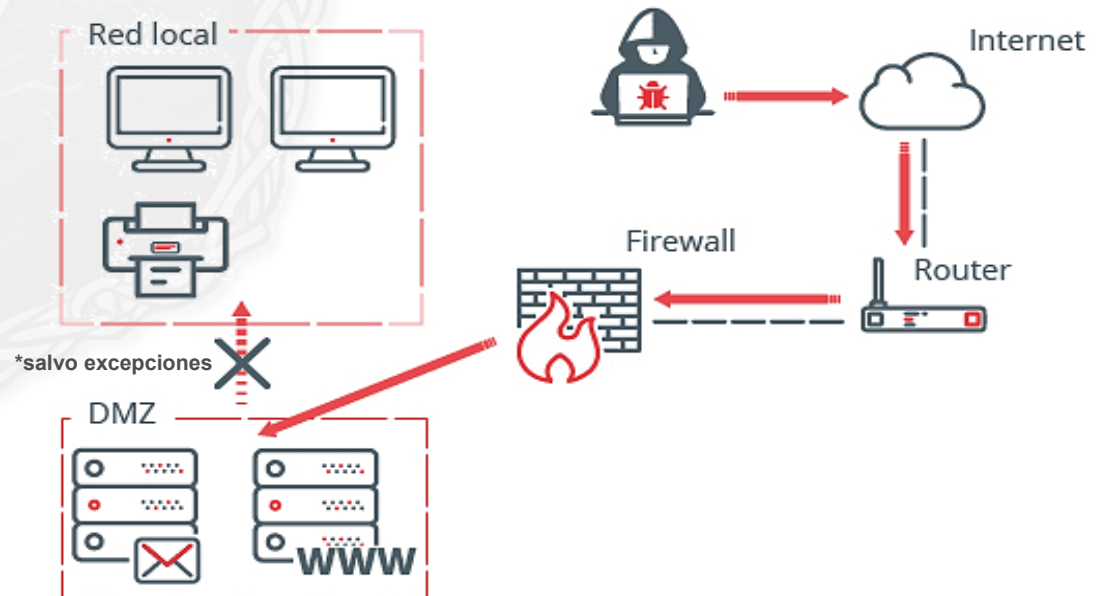
- Servidores web, servidores de e-mail...

- **Los servidores de una DMZ...**

- Permiten conexiones desde Internet y la red local
 - **Pero las conexiones de la DMZ a la red local están prohibidas** (salvo excepciones)
- Contiene los servicios **más propensos a verse comprometidos**
 - Es decir, nos hacen “de colchón” para “los malos” 😊

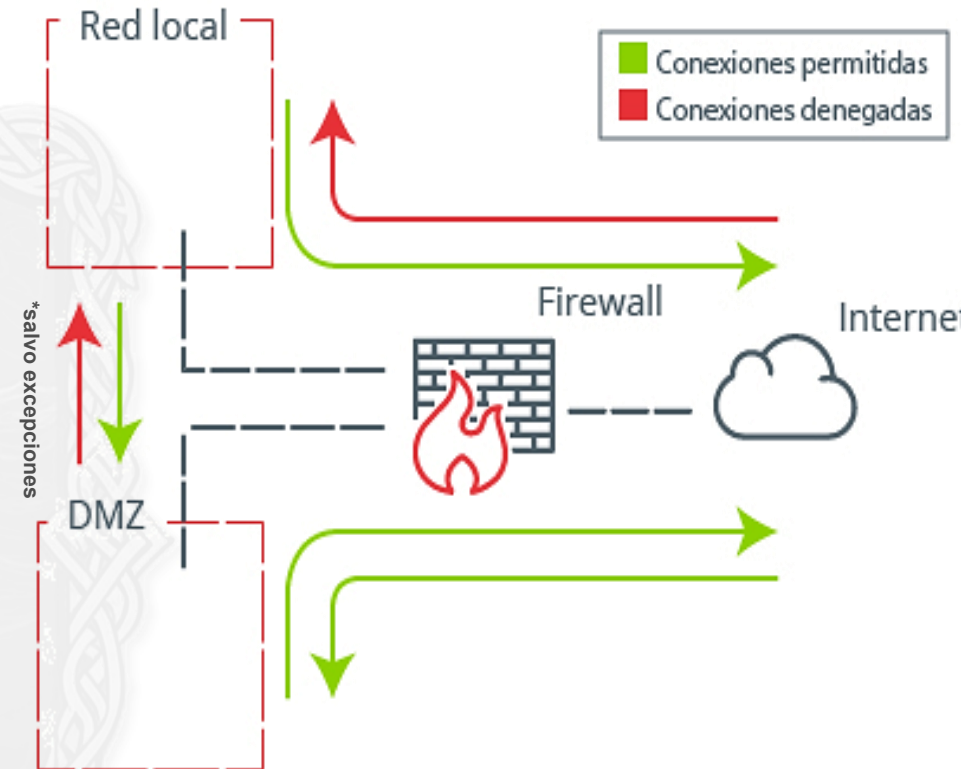
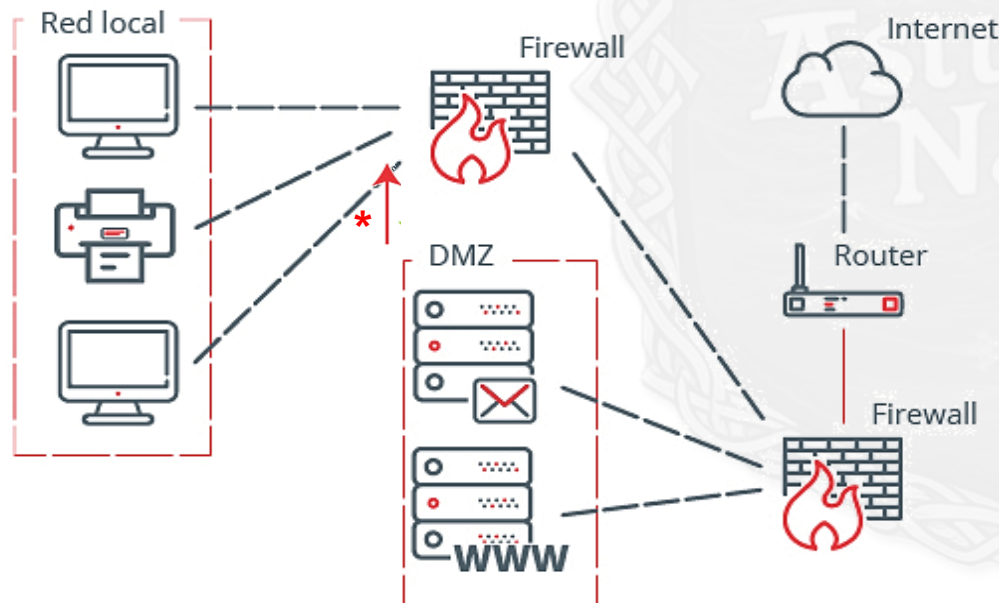


Fuente: <https://www.incibe.es/protege-tu-empresa/blog/dmz-y-te-puede-ayudar-proteger-tu-empresa>



DEMILITARIZED ZONE O DMZ

- Se pueden usar dos (o más) firewalls para aumentar la seguridad de las DMZ
 - En cualquier caso, *¿Qué pasa si un servidor de una zona se compromete? ¿Cómo ayudan las zonas a la seguridad?*



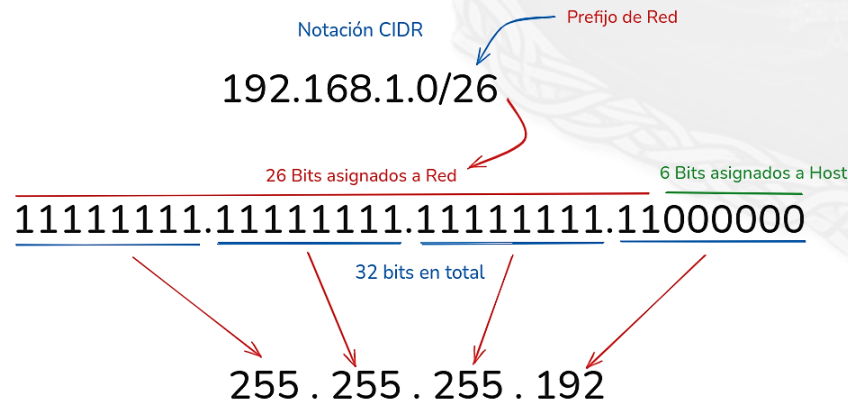
Hazte a la idea de que un firewall es una máquina Linux a la que contactas en uno de sus puertos. Puede estar configurado para que eso se convierta en una petición a una máquina que está "detrás" de él, en otra red (port forwarding). Pero tú nunca lo sabrás, el firewall hará de intermediario, y así conseguimos **aislamiento**. Fuente: <https://www.incibe.es/protege-tu-empresa/blog/dmz-y-te-puede-ayudar-proteger-tu-empresa>

Fuente: <https://www.incibe.es/protege-tu-empresa/blog/dmz-y-te-puede-ayudar-proteger-tu-empresa>

REGLAS POR ZONA VS REGLAS POR MÁSCARAS CIDR PARA REDES



- Ambas se pueden usar conjuntamente para una buena granularidad de las reglas
 - Las reglas basadas en zonas son ideales para definir el **flujo general de tráfico** permitido o denegado entre las principales zonas de la red (“grano gordo”)
 - Estas son las que **se suelen definir primero**
 - Las reglas basadas en **rangos de red** (o IPs/subredes) aplican políticas de seguridad a segmentos de red **mucho más específicos** (“grano fino”)
 - Ejs.: Permitir que solo un servidor específico (identificado por su IP) en la DMZ acceda a un recurso particular en la LAN, bloquear el tráfico de un rango de IPs malicioso conocido proveniente de la WAN...
 - **Permiten una mayor granularidad y control sobre el tráfico** dentro de una misma zona (o entre zonas)
 - **Permitiéndote ser muy específico** sobre qué hosts o subredes pueden comunicarse y de qué forma
 - Por ello, **se definen después** “ajustando” el primer tipo de reglas



Class A	<table><tr><th>Network</th><th>Host</th><th>Host</th><th>Host</th></tr><tr><td>255</td><td>0</td><td>0</td><td>0</td></tr></table>	Network	Host	Host	Host	255	0	0	0	/8
Network	Host	Host	Host							
255	0	0	0							
Subnet Mask										
Class B	<table><tr><th>Network</th><th>Network</th><th>Host</th><th>Host</th></tr><tr><td>255</td><td>255</td><td>0</td><td>0</td></tr></table>	Network	Network	Host	Host	255	255	0	0	/16
Network	Network	Host	Host							
255	255	0	0							
Subnet Mask										
Class C	<table><tr><th>Network</th><th>Network</th><th>Network</th><th>Host</th></tr><tr><td>255</td><td>255</td><td>255</td><td>0</td></tr></table>	Network	Network	Network	Host	255	255	255	0	/24
Network	Network	Network	Host							
255	255	255	0							
Subnet Mask										



Firewalls perimetrales y vigilancia de red IDS/IPS

Los policías entre redes y zonas



HOST FIREWALLS VS PERIMETRAL FIREWALLS

- Cuando los firewalls pueden restringir conexiones entre distintas redes o zonas, se denominan **firewalls perimetrales**

- La política por defecto es **descartar todas las conexiones no permitidas** explícitamente entre 2 redes o zonas, bidireccionalmente
- Son una "**primera línea de defensa**"
 - Si se rompe, los atacantes tendrán acceso a una red restringida
 - Por eso **no protegen contra todas las amenazas modernas**
 - Ej.: Alguien se conecta por VPN a tu red Interna con un dispositivo infectado



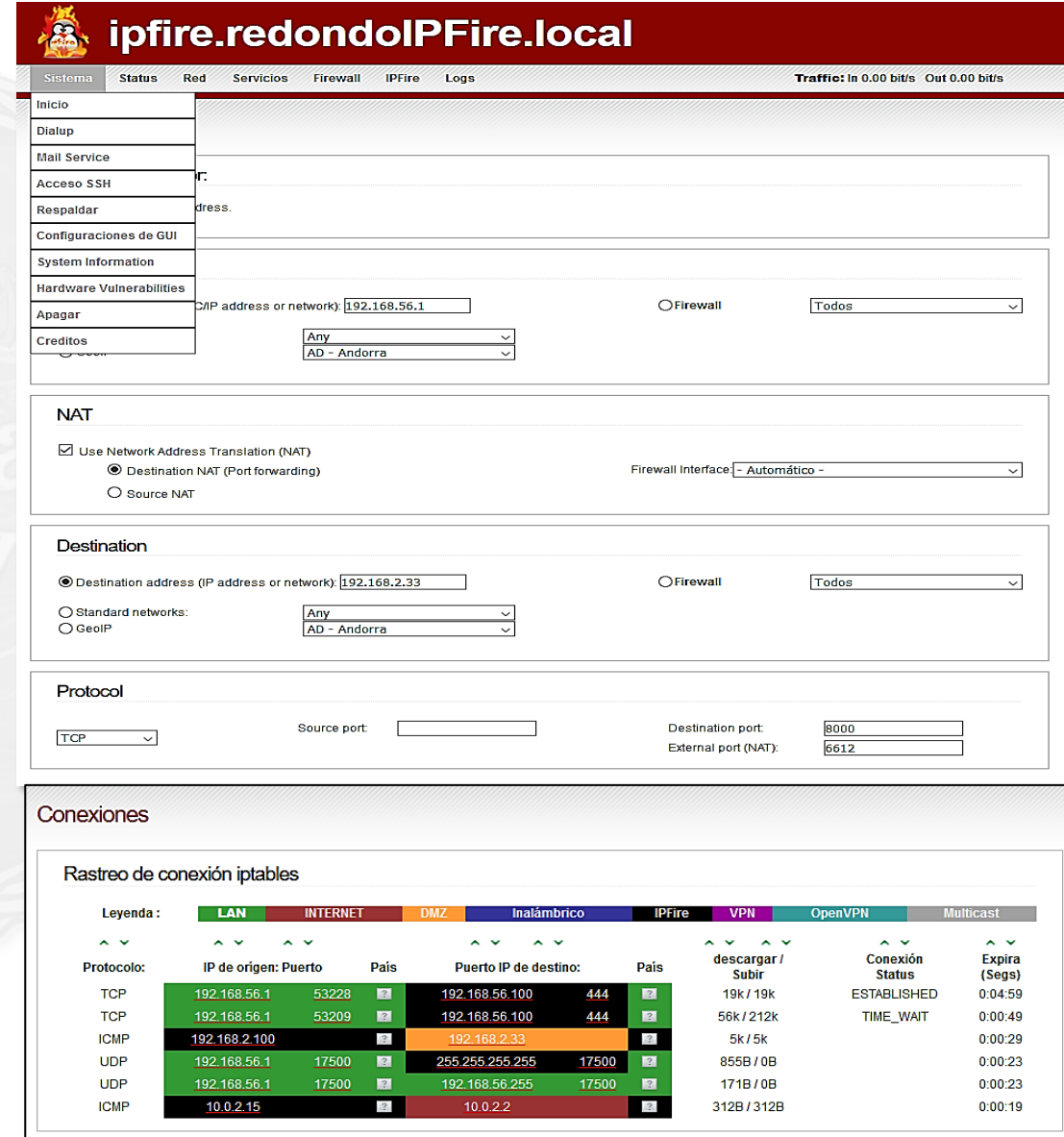
- **Son complementarios** a los firewalls de host, no los reemplazan

- ¡Defensa en profundidad implica redundancia de defensas! 😊
- ¿Cómo puedes disponer de uno? Ejs.:
 - Tu router puede tener uno
 - Hay también firewalls-SO. Ej.:
 - **pfSense**: <https://www.pfsense.org/>
 - **IPFire**: <https://www.ipfire.org/>
 - Muchos proveedores de nube lo ofrecen



EJEMPLOS DE FIREWALLS SPI PERIMETRALES

- Las imágenes son del perimetral IPfire
- Este tipo de firewalls ofrecen extras como...
 - **Logging completo** de todas las conexiones que pasan por él
 - **IDS/IPS** gracias a implementar **DPI** (siguiente hoja)
 - Que va de la mano con el logging mencionado
 - **Acceso remoto seguro al integrar un servidor VPN** (final de este tema)
 - ...



The screenshot shows the IPFire web interface for 'ipfire.redondoIPFire.local'. The interface includes a sidebar menu with options like 'Inicio', 'Dialup', 'Mail Service', 'Acceso SSH', 'Respalidar', 'Configuraciones de GUI', 'System Information', 'Hardware Vulnerabilities', 'Apagar', and 'Creditos'. The main content area is divided into several sections: 'Sistema' (System), 'Status', 'Red' (Network), 'Servicios' (Services), 'Firewall', 'IPFire', and 'Logs'. The 'Firewall' section is currently selected, showing configuration options for 'Firewall' and 'NAT'. The 'NAT' section includes options for 'Use Network Address Translation (NAT)' and 'Destination NAT (Port forwarding)'. The 'Destination' section shows the 'Destination address (IP address or network)' set to '192.168.2.33'. The 'Protocol' section shows 'TCP' selected. The 'Conexiones' (Connections) section displays a table of active connections, including source and destination IP addresses, ports, and connection status.

Protocolo:	IP de origen: Puerto	País	Puerto IP de destino:	País	descargar / Subir	Conexión Status	Expira (Segs)
TCP	192.168.56.1 53228	ES	192.168.56.100 444	ES	19k / 19k	ESTABLISHED	0:04:59
TCP	192.168.56.1 53209	ES	192.168.56.100 444	ES	56k / 212k	TIME_WAIT	0:00:49
ICMP	192.168.2.100	ES	192.168.2.33	ES	5k / 5k		0:00:29
UDP	192.168.56.1 17500	ES	255.255.255.255 17500	ES	855B / 0B		0:00:23
UDP	192.168.56.1 17500	ES	192.168.56.255 17500	ES	171B / 0B		0:00:23
ICMP	10.0.2.15	ES	10.0.2.2	ES	312B / 312B		0:00:19

FIREWALLS CON DEEP PACKET INSPECTION (DPI)

- **Técnica avanzada de inspección de tráfico de red que tienen algunos firewalls**
 - Va más allá del análisis de las cabeceras de los paquetes (IPs, puertos, etc.) de muchos firewalls
- **Examina en detalle el contenido (el "payload") de cada paquete que pasa por él**
 - **Inspecciona todos los protocolos y capas** usados en la transmisión
 - Se puede hacer un paralelismo con una carta postal
 - **Un firewall sin DPI** mira remitente y destinatario en el exterior del sobre
 - **Uno con DPI** abre el sobre, lee y analiza el contenido de la carta
 - *¿Qué problema crees que tienen desde el punto de vista del usuario?*
- **Se puede considerar que un WAF (Nivel 1) hace una forma especializada de DPI**
 - Con enfoque y alcance **específicos para tráfico HTTP/HTTPS** (u otros protocolos relacionados)



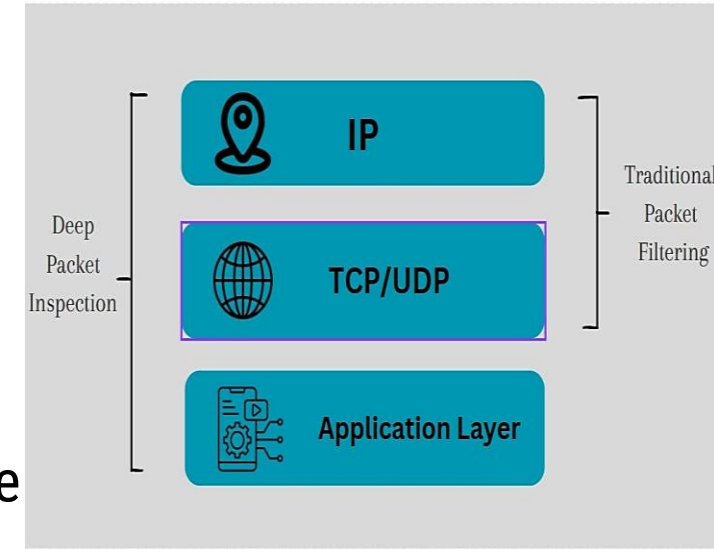
Stateful packet inspection looks at the header and footer of the packet.



Deep packet inspection examines the data part of a packet.

FIREWALLS CON DEEP PACKET INSPECTION (DPI)

- **Al analizar el contenido completo de los paquetes, un firewall con DPI puede**
 - **Identificar la aplicación y el protocolo real en uso:** Analizando su comportamiento
 - **Implementar controles de aplicaciones**
 - **Filtrar contenido específico** (Ej.: ciertas webs)
 - **Aplicar políticas de calidad de servicio (QoS):** Priorizar ciertos tipos de paquetes para asegurar el rendimiento de servicios
 - Ej.: voz sobre IP, streaming de video...
 - **Detectar y bloquear malware y amenazas avanzadas**
 - **Permitir la detección y prevención de intrusiones en la red:** Es fundamental para implementar IDS/IPS (siguiente hoja)



Un firewall con DPI es tremendamente “cotilla” 😊. Bueno para la seguridad, malo para la privacidad. Elige qué priorizas en cada parte de tu infraestructura. Fuente:

<https://medium.com/@chandulanethmal/a-deep-dive-into-deep-packet-inspection-6151865cf0c3>

IDS o NIDS (NETWORK INTRUSION DETECTION SYSTEM)



- Herramienta de seguridad diseñada para **monitorizar y analizar** el tráfico de una red en busca de actividades maliciosas, no autorizadas o anómalas
 - Busca **identificar patrones sospechosos de tráfico de red** que puedan indicar un intento de intrusión, un ataque en curso o una violación de las políticas de seguridad establecidas
 - Es **pasivo** y **genera alertas** si detecta alguna anomalía
 - Da un extra de detección al bloqueo de los firewalls
- Inspecciona el tráfico en un punto estratégico de la red donde está desplegado
 - **Detección basada en firmas**: Compara el tráfico con una BBDD de firmas conocidas de ataques
 - **Detección basada en anomalías**: Crea un perfil de comportamiento normal de la red y luego busca desviaciones significativas de ese perfil (**técnicas de IA** , **SI**)
 - *¿Cuál de los dos métodos detectaría posibles ataques zero day?*

IPS (INTRUSION PREVENTION SYSTEM)



- Tecnología de seguridad de red que monitoriza continuamente el tráfico y/o la actividad del sistema para **detectar y prevenir** actividades maliciosas, incluyendo
 - **Monitorización y análisis:** Igual que el IDS, basado en firmas o en anomalías
 - **Detección de amenazas:** Identifica actividades sospechosas como intentos de intrusión, propagación de malware, escaneos de puertos, denegación de servicio (DoS), entre otros
 - **Prevención activa:** Una vez detectada una amenaza, **toma acciones inmediatas** para mitigarla
 - Ejs.: Bloquear paquetes maliciosos, reiniciar la conexión, bloquear IPs de origen, alertar a los administradores de seguridad...
 - **Log e informes:** Registra información relevante sobre los eventos detectados y prevenidos
- El IPS suele estar **detrás** del firewall (examina el tráfico que éste permite)
 - Para **detectar y prevenir ataques más sofisticados** que el firewall no ha podido bloquear
- *¿Hay dispositivos que hacen las dos cosas?*
 - Sí, se llaman IDPS 😊



What is IDS & IPS ?

by @ [SecurityGuill](#)

What is an IDS?



- An IDS (**Intrusion Detection System**) **analyzes and monitors network traffic** for signs that attackers use a **known cyber threat** to **infiltrate** or **steal data** from your **network**.

- IDS systems **compare current network activity with a database of known attacks** to detect various types of behaviors such as security policy violations, malware and port scanners.



- With IDS systems, it is necessary for a human or other system to **take over to review the results and determine the actions to be implemented**, which can be a full-time job depending on the amount of traffic generated by day.



Common points

- Both read **network packets** and compare the contents to a **database of known threats**.

Why you need IDS/IPS Technology

- **Conformity reasons** (To prove that you have implemented the necessary means to protect your data)

- To **protect your data** (especially if you collect a **large amount of personal data**)

- **Automation**

What is an IPS?



- An IPS (**Intrusion Prevention System**) acts in the same area of the network as a **firewall**, between the outside world and the **internal network**.



- IPS systems proactively **reject network packet** based on a **security profile** if these packets represents a **known threat**.

- The goal of the IPS is to **capture dangerous packets** and **remove them before they reach their target**.



- It is more passive than an IDS and simply requires **regular updating of the database** to incorporate **new threat information**.



Follow @ [SecurityGuill](#) on *Twitter* for more about *Infosec / Cybersecurity*

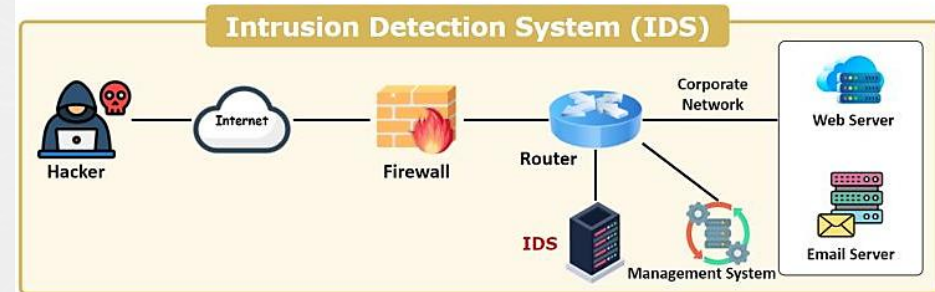
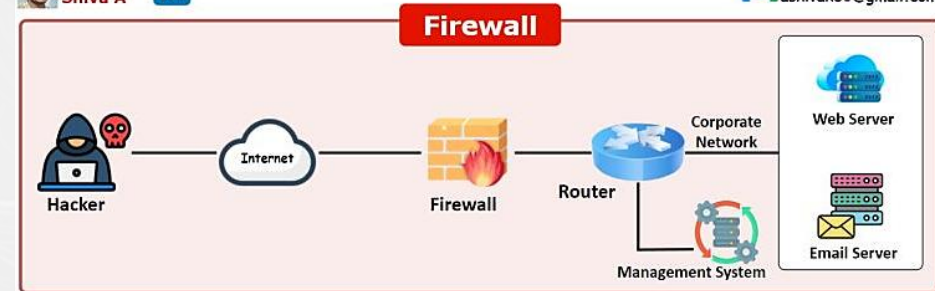
¿CÓMO PUEDO DISPONER DE UNO?

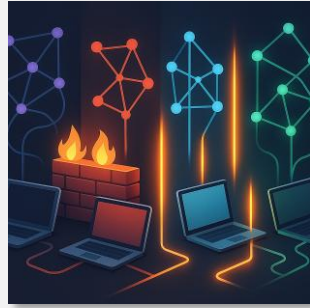
- En primer lugar, debes seleccionar **el punto de la red adecuado** para ello
 - Uno por el que pase todo el tráfico a monitorizar
- Elegido el punto adecuado, puedes, según los recursos que tengas disponibles
 - **Instalar alguno libre** (Maltrail, Suricata, SNORT...) sobre el SO de la máquina por la que pase el tráfico
 - **Usar uno híbrido**
 - Instalar sobre una máquina algún SO especializado en ser un firewall, que suelen incluir IDS y/o IPS
 - **Comprar algún dispositivo con uno integrado**
 - Algunos routers comerciales también los integran

Firewall vs IDS vs IPS

Created by: Shiva A 

 www.linkedin.com/in/ashivak01/
ashivak01@gmail.com





Montando infraestructuras seguras más complejas

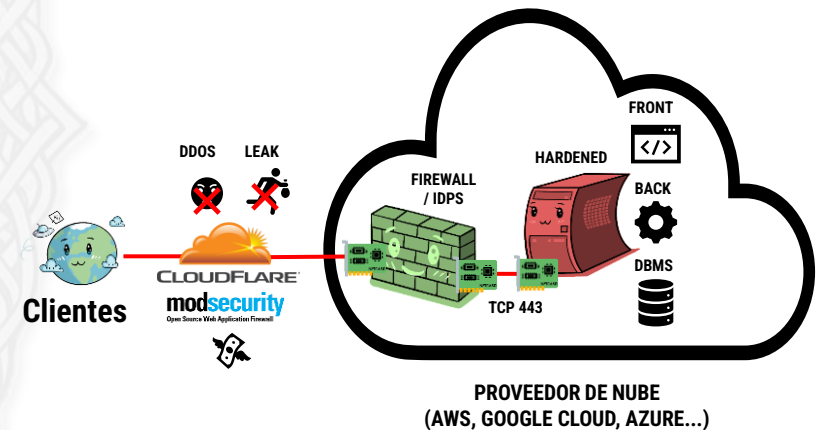
Montar redes de alta seguridad puede no requerir un esfuerzo económico tan elevado como piensas



MONTANDO INFRAESTRUCTURAS CON PRESUPUESTO MODERADO

● Ideas de infraestructuras seguras con lo

- **AllInOneFWIDS:** Más seguridad, pero sigue sin separar servicios
 - El proxy del **Nivel 1** pasa a ser **un firewall con IDS/IPS integrado**
 - Si no tenemos suficiente presupuesto, **podemos comprar un router comercial** con uno integrado
 - Añade un gran extra de seguridad y monitorización de red
- **El WAF lo hemos movido a la CDN**
 - Hay dispositivos **firewall/IDPS/WAF** pero son **más caros y complejos** (los veremos en el **Nivel 3**)
 - Podemos adquirir servicios de seguridad de pago más avanzados en la CDN
 - Si nos los podemos permitir...



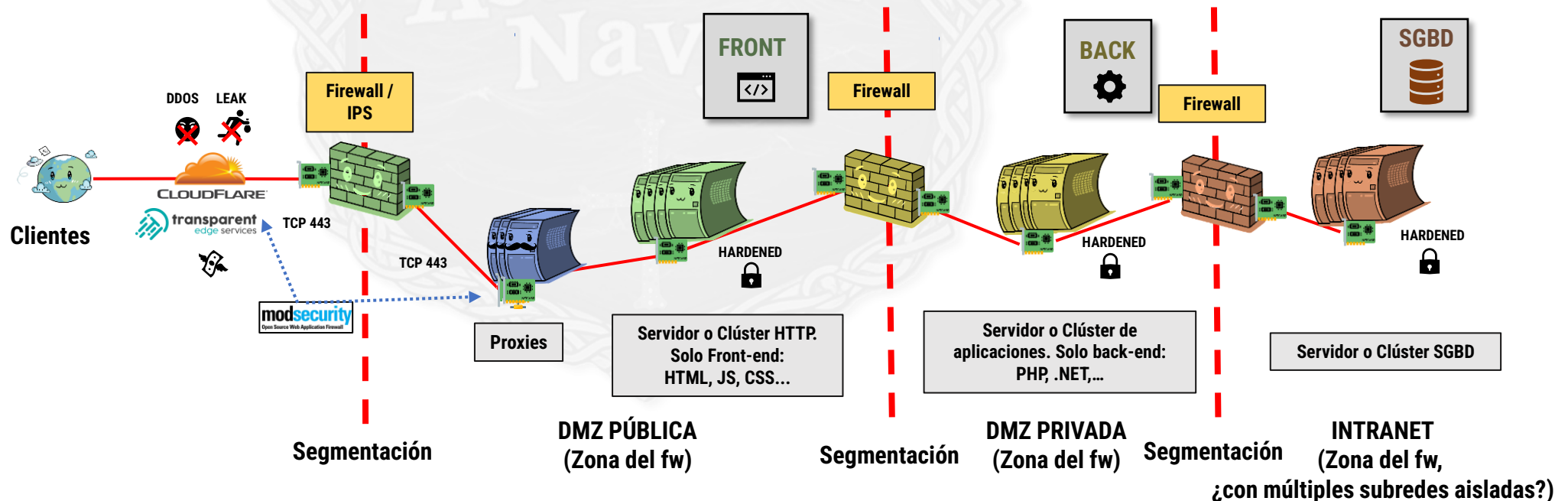
Aquí hemos puesto la infraestructura en nube, pero el modelo sirve igual en un entorno on-premise

MONTANDO INFRAESTRUCTURAS CON PRESUPUESTO ELEVADO

- **DetachedSimpleFWIDS / DetachedFullFWIDS:** Similar a **Nivel 1**, pero cambiando los proxies por firewalls como en la solución anterior
 - Solo el externo llevaría acoplado un IPS (asumimos tráfico “interno” más fiable para ahorrar)
 - Podría **montar clústeres, balanceadores de carga, proxies...** (L-62 “Princesa de Asturias”)
 - Según la carga de trabajo / necesidades de escalado
 - Podemos mantener **varias subredes en la zona Intranet** (Empleados, Dev, Test...) con reglas del firewall

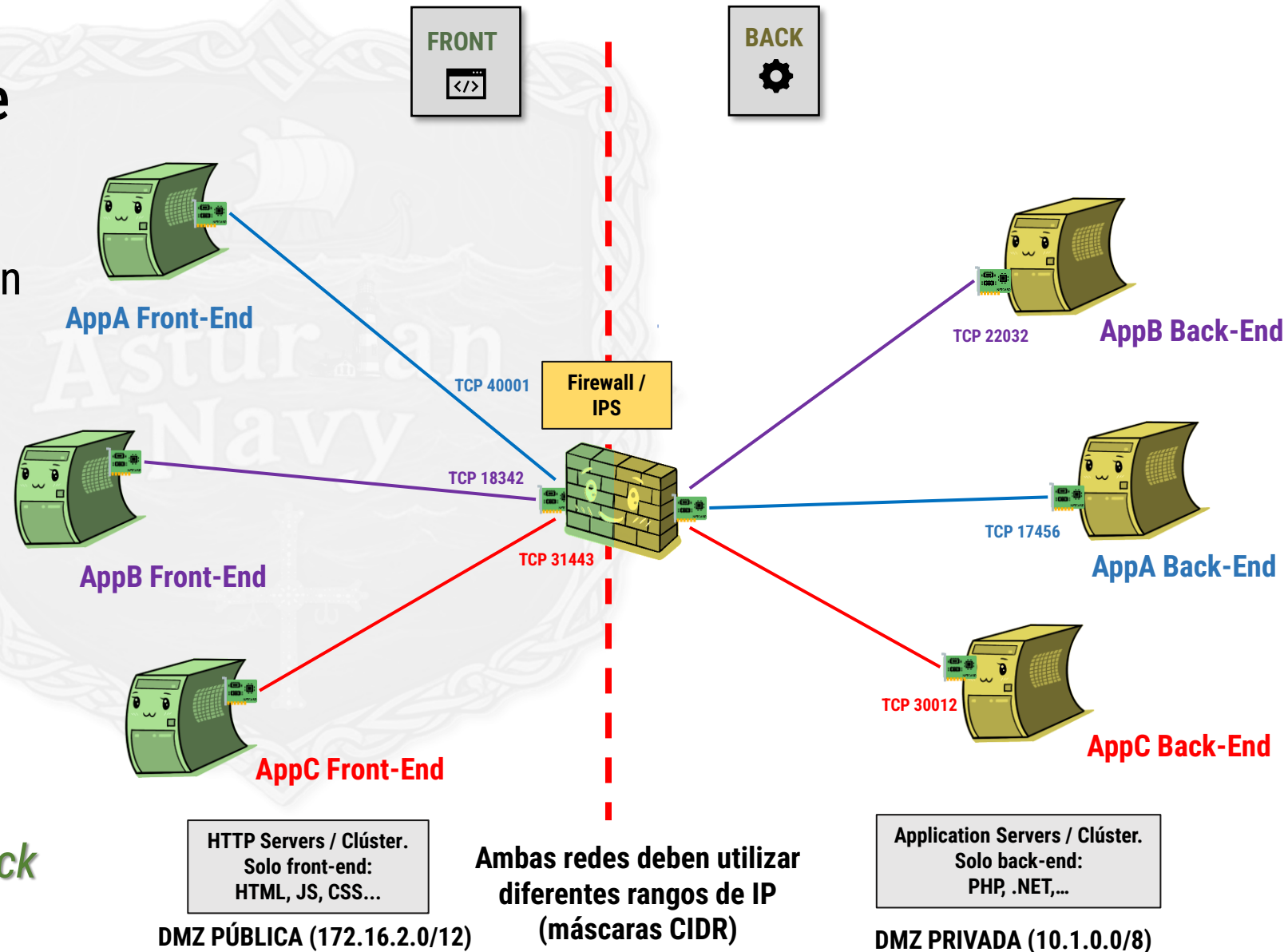
¿Dos o tres zonas?
Depende de tu presupuesto poder separar back y SGBD. Más capas, más flexibilidad y resistencia a ataques.

Esto además admite esquemas híbridos (parte está on-premise, parte en nube)



AISLAMIENTO DE CERCA: EJEMPLO DE REENVÍO CON UN FIREWALL

- Las reglas de firewall saben qué máquina del front puede acceder a una del back
 - Es decir: el frontend de la **AppA** **nunca** se pondrá en contacto con el backend de la **AppB**
- Cada máquina frontend se conecta a un puerto de firewall diferente
 - Si se aprueba, el firewall **hace forwarding** a la máquina adecuada en el backend
 - Las respuestas se redirigen automáticamente
 - *¿Pueden las máquinas front y back de AppA verse directamente?*



¿CREES QUE LO HAS ENTENDIDO TODO? ¡AUTOEVALÚATE!



● Asegúrate de haber entendido lo siguiente

- *Cómo funciona el forwarding de puertos y por qué, gracias a él, logramos el aislamiento completo entre redes con un firewall*
- *El propósito de una zona de red y lo que permite hacer*
- *Para qué sirve una zona especial llamada DMZ en un entorno de producción*
- *El propósito de un firewall perimetral y en qué sentido son distintos de un firewall de host*
- *Todo lo que implica el DPI de un firewall, lo que permite y por qué puede ser un problema en algunos entornos*
- *La vigilancia de paquetes de red que permite el DPI y los dos tipos de sistemas de vigilancia que existen (detección y/o prevención)*
- *Que algunos firewalls no solo bloquean y aíslan, sino que también pueden usarse para detectar amenazas que podemos estudiar acoplando un sistema de vigilancia como los anteriores*
- *Construcción de infraestructuras avanzadas que usen los conceptos explicados anteriormente*

< Ir al Índice



INFRAESTRUCTURAS SEGURAS AVANZADAS (NIVEL 3)

Máxima protección para las infraestructuras y los activos



   VLAN >

 NGFW, UTM >

 Construcción inf. >



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

¿QUÉ VAS A APRENDER EN ESTE BLOQUE?

- Esta sección te permitirá entender los conceptos que te permitirán planificar infraestructuras con seguridad muy avanzada
 - La **separación virtual** de redes que permiten algunos dispositivos de red con las **VLAN**
 - Los **tipos de soluciones de seguridad más avanzados** (y caros) posibles para tus infraestructuras: **NGFW y UTM**
 - Como **diseñar infraestructuras de muy alta seguridad** usando todos los conceptos vistos, basado en un **máximo aislamiento** entre partes
 - Cómo estas infraestructuras de alta seguridad **necesitan de una mayor vigilancia** que la que proporcionan IDS/IPS





VLANs

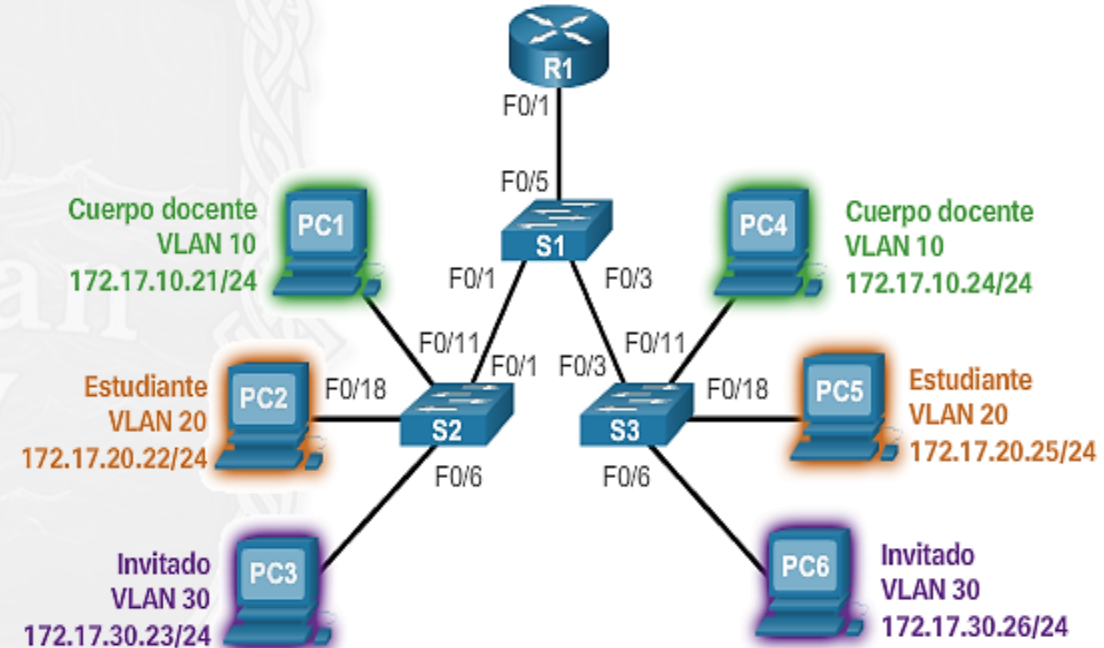
Cuando las tarjetas de red admiten virtualización



CREACIÓN Y USO DE VLANs

- Las VLANs separan lógicamente el tráfico de red de las LAN
 - <https://www.ibm.com/docs/es/aix/7.1?topic=cards-virtual-local-area-networks>
- Hazte a la idea de que son como las MVs, pero con tarjetas de red 😊
 - Aunque pasen por la misma tarjeta de red física, **los paquetes de distintas VLAN no se ven entre ellos**
- Separan tráfico en función de criterios establecidos de antemano
 - Su “riesgo”, la **calidad de servicio** a dar a los clientes, **tipo de tráfico** (control y monitorización de operaciones VS tráfico “normal”)...

Beneficios de las redes VLAN

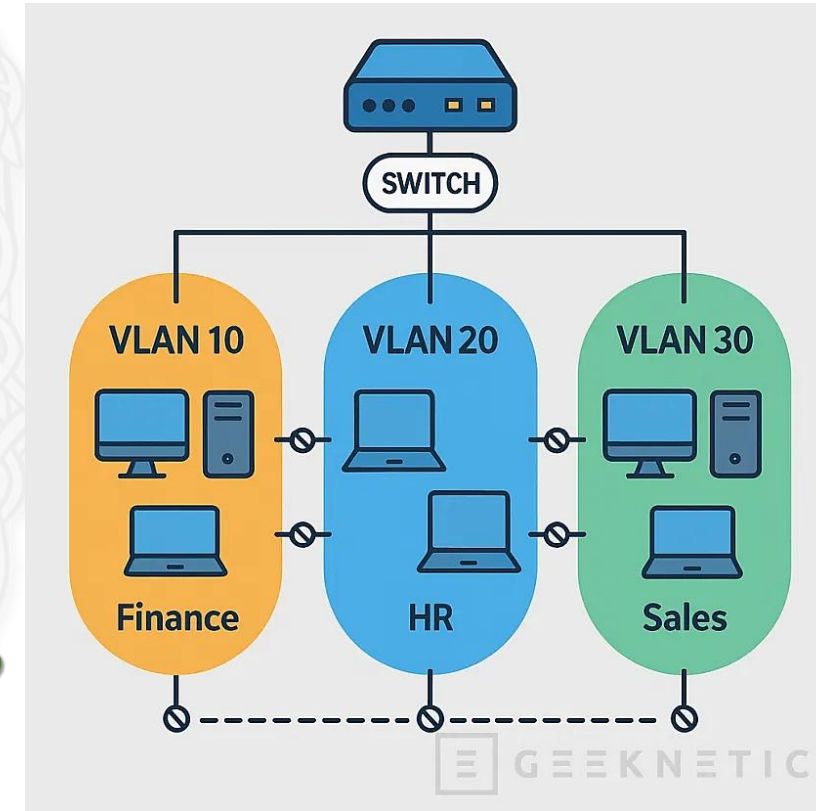


Si un adversario no puede ver el tráfico de control, el que contiene datos altamente sensibles, etc. debido a que está en una VLAN distinta, se lo estás poniendo mucho más difícil, al ser una barrera más a saltar para ellos. Fuente:

<https://interpolados.wordpress.com/2017/05/01/beneficios-de-las-redes-vlan/>

CREACIÓN Y USO DE VLANs

- **Un mismo NIC (tarjeta de red) soporta manejar varias LANs independientes**
 - Se aíslan entre sí creando **versiones virtuales de ese NIC**
 - Etiquetando las redes que maneja con un nombre diferente (Ej.: VLAN1, VLAN2...)
 - Así cada servidor de la infraestructura puede usar dos o más VLANs y separar el tráfico
 - La **VLAN1** se recomienda para **redes de administración**
- **Son otra forma de “defensa en profundidad”; ¿Por qué?**
 - VoIP, tráfico de empleados (navegación, e-mail...), tráfico Wi-Fi...
 - La clave para una buena implementación de VLAN es
 - **Planificarlas** rigurosamente de antemano
 - Comprar **hardware y software** que **soporte su creación y gestión**



Si hay redes que no deben verse nunca, separarlas directamente a nivel de tarjeta de red y ahórrate problemas. Fuente:

<https://pronetic.geeknetic.es/Guia/3194/VLANs-en-Redes-Empresariales-Como-segmentar-tu-Red-con-cabeza-y-evitarte-sustos.html>



Next-Generation FireWalls (NGFW) y Unified Threat Management (UTM)

Firewalls con superpoderes



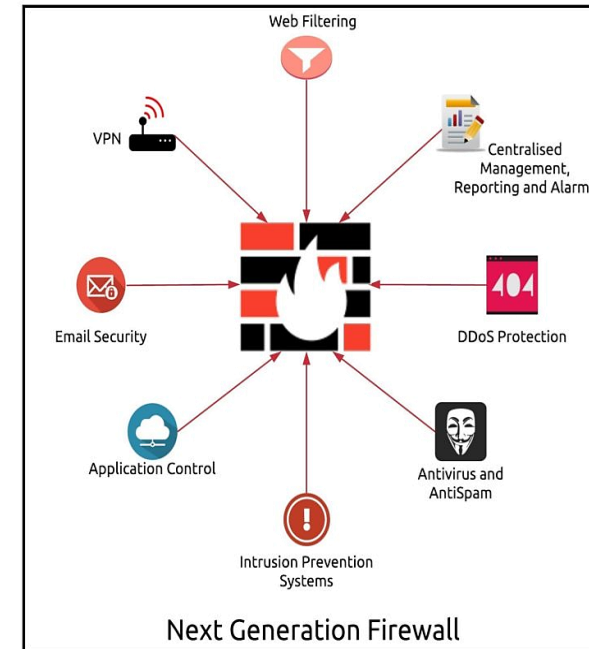
NEXT-GENERATION FIREWALLS (NGFW)

- Seguridad de red más inteligente, cara y completa
 - FortiGate, Forcepoint, Cloudflare, PortMaster (<https://safing.io/features/>) ...
- Pensadas contra ataques avanzados y dirigidos, integrando
 - **Intent-based networking:** Decir qué quieres y que se configure para ello
 - <https://www.cisco.com/c/en/us/solutions/intent-based-networking.html>
 - **DPI con IDPS** integrados
 - **Detección avanzada de malware** basada en reputación
 - **Reconocimiento y control de aplicaciones y usuarios**
 - Identifican aplicaciones y aplican políticas de seguridad concretas para ellas
 - Uso de **inteligencia de amenazas** (Threat Intelligence) externas
 - Obtiene información (y bloquea) **nuevas amenazas**, **malware** y webs maliciosas
 - **Identificación y control de usuarios:** Permiten control de acceso más granular basado en quién es el usuario, **no solo su IP**
 - Con esto, abren la puerta a **políticas Zero Trust**



Un NGFW comercial. Fuente: <https://www.amazon.com/Fortinet-FortiGate-Hardware-FortiCare-Premium/dp/B0CFG5GR7J>

NGFW



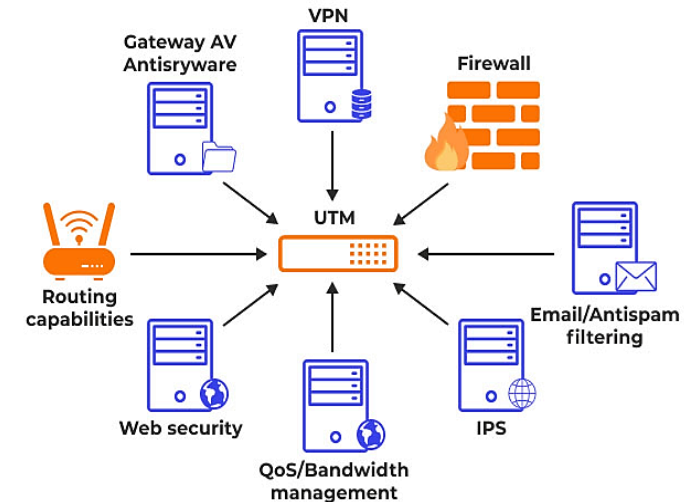
Algunos NGFW incluyen más funcionalidades y son una solución “todo-en uno” en protección de red. Fuente: <https://firewall.firm.in/what-is-a-next-generation-firewall-ngfw/>

¿QUÉ ES UN SISTEMA UTM?

- **Soluciones de seguridad de red que unifican varias funciones de seguridad en un solo dispositivo**
 - Para **simplificar la gestión de la seguridad** y proporcionar una defensa integral contra una amplia gama de ciberamenazas
 - Ya no implementas y administras productos de seguridad individuales para cada función (**firewall**, antivirus, etc.)
 - Un UTM **integra estas capacidades** en una solución unificada
 - La visibilidad, el control y la administración de la seguridad de la red está **en un solo punto**
- **Pueden simplificar la seguridad de forma que pueda ser atractivo para pequeñas y medianas empresas**

wallarm

UTM A single appliance Blended threats protection



Los UTM son realmente una “navaja suiza” o un “todo en uno” en temas de gestión y administración de seguridad. Fuente: <https://www.wallarm.com/what/unified-threat-management>

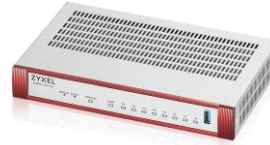
¿QUÉ ES UN SISTEMA UTM?

- **Funciones de seguridad clave que suelen incluir los sistemas UTM son**
 - **Firewall SPI perimetral**
 - **IDPS**
 - **Antivirus / antimalware:** Escanea el tráfico de entrada y salida, así como los archivos, en busca de virus, gusanos, troyanos, ransomware y otro malware
 - **Filtrado web:** Permite controlar y restringir el acceso de los usuarios a sitios web basados en categorías, reputación o políticas definidas
 - Previene acceder a contenido inapropiado o malicioso (como los DNS seguros del **Nivel 1**)
 - **Antispam:** Filtra el correo electrónico no deseado, reduciendo la cantidad de spam y protegiendo contra ataques de phishing
 - **VPN:** Para establecer conexiones seguras y cifradas con la red que protege (sección siguiente)
 - **Prevención de pérdida/fuga de datos (DLP):** Ayuda a **prevenir la transmisión no autorizada de datos sensibles** fuera de la red, detectándolos en el tráfico que examina
 - **Control de aplicaciones:** Permite identificar y controlar el uso de aplicaciones dentro de la red
 - Priorizando el tráfico o bloqueando aplicaciones no deseadas

¿CÓMO PUEDO HACERME CON UN UTM?

- Son hardware dedicado de fabricantes conocidos
 - Comunes en entornos empresariales (PYME, mediana empresa) y domésticos avanzados
- Hay muchos fabricantes, pero algunos son
 - Cisco ASA (Adaptive Security Appliance), Fortinet FortiGate, WatchGuard Firebox...
- Hay que mirar lo que ofrecen, mantenimiento, etc.
 - Y, sobre todo, el modelo de suscripción al software que integran
 - Ej.: Periodicidad del pago, límites de las licencias, actualizaciones y soporte, ofertas...

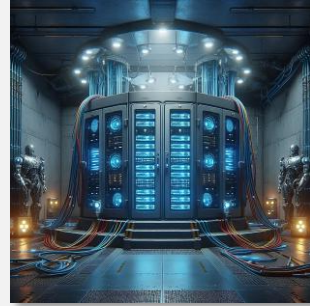
Muchos venden el hardware y luego suscripciones anuales al software que integra. Fuente: <https://www.amazon.es/Cortafuegos-Zyxel-Seguridad-Recomendado-USGFLEX100HP/dp/B0CKZF99XF/>



Licensed vs. Unlicensed

● Protected
● Not Protected (Optional Add-On)

	WHY IMPORTANT?	UNLICENSED (HARWARE ONLY)	LICENSED (BUNDLE)
 Network Address Translation	Hides IP addresses on the network from the internet	●	●
 Stateful Packet Inspection	Checks that packets match active connections or blocks traffic that isn't a match	●	●
 Distributed Denial of Service	Blocks malicious "bombarding" of an IP address to cripple it, aka "ping of death"	●	●
 VPN	Securely encrypts data sent between locations across the internet	●	●
 Anti-Malware/Anti-Virus	Scan files at the gateway for viruses and other threats like ransomware as a first line of defense	●	●
 Web Filtering/Content Filtering	Block access to malicious or risky web sites by category like gambling, adult, social media	●	●
 Sandboxing/Zero Day Threats	Cloud-based sandbox technology against unknown and zero day threats	●	●
 IPS/IDP	Deep-packet intrusion detection and prevention inspection against known attacks from the network	●	●
 Application Patrol	Automatically categorize and manage network application usage by allowing or blocking specific applications	●	●
 Reputation Filter	Block botnet infection and prevent drive-by download from infected websites via IP and URL detection	●	●
 Email Security/Anti-Spam	Fast detection to block spam and phishing mail with malicious content or attachments	●	●
 SecuReporter	Cloud-based security analytics and report with 30-day log retention	●	●
 Nebula Professional Pack	A full feature set of cloud configuration, deployment, monitoring and management	●	●



Construcción de infraestructuras altamente seguras

Apostándolo todo a la seguridad (con una inversión acorde)



¿QUÉ VAS A APRENDER EN ESTE BLOQUE?



- **Vamos a ver unos principios de construcción de infraestructuras altamente seguras, cuando se cuenta con recursos suficientes**
 - Sus **componentes principales**, usando algunos de niveles anteriores
 - Poniendo el foco en la importancia de la **separación por capas**
 - Lo crítico que es tener una **red de administración y control separada** de la infraestructura
 - Decisiones a tomar en la construcción de una infraestructura

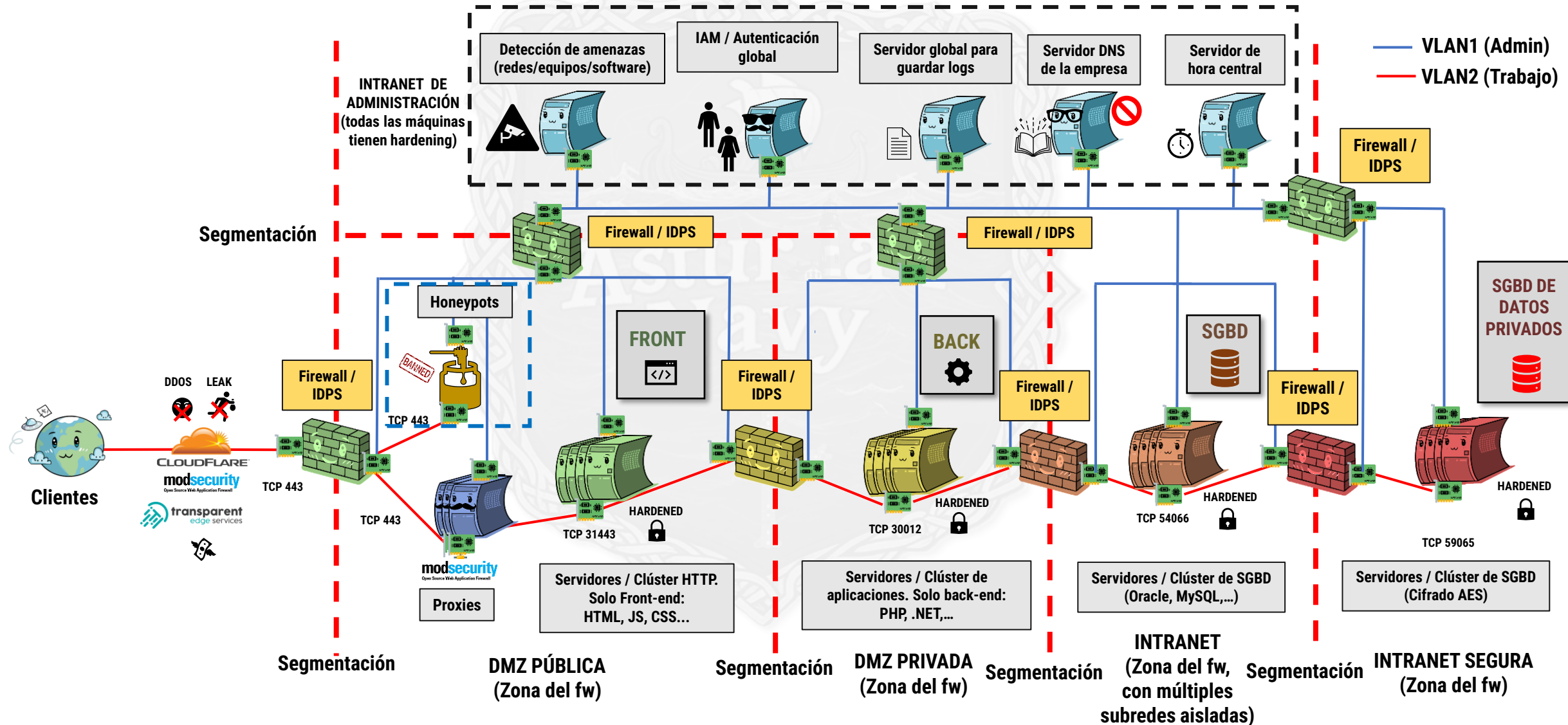
SECURE NETWORK INFRASTRUCTURE (SNI)



- El nivel de seguridad de la infraestructura depende de
 - El **presupuesto** (una seguridad sólida requiere inversiones sólidas)
 - Capacidad para **manejar infraestructuras** de diferentes complejidades
 - La **criticidad** de datos/servicios alojados
 - **Regulaciones/certificaciones legales** a cumplir
- Veamos un ejemplo de una infraestructura segura (y compleja), evolución de las anteriores
 - La **SNI** (Secure Network Infrastructure)
 - Todos o parte de sus elementos se pueden **implementar en un proveedor de nube** para ahorrar costes de administración / dinero
 - Sin importar la capa, toda conexión bajo el protocolo HTTP que no sea estrictamente para pruebas de desarrollo **debe usar HTTPS**
 - Lo expuesto en producción **no debe producir avisos en el navegador**



SECURE NETWORK INFRASTRUCTURE (SNI)



SECURE NETWORK INFRASTRUCTURE (SNI): ZONAS

- Tiene 5 subredes/zonas independientes y aisladas entre ellas
 - La **DMZ pública**, con **solo el front-end de las aplicaciones**
 - Solo expone públicamente los servicios necesarios (**minimización**)
 - Ofreciendo la **mínima información** acerca de **software** y tecnologías usadas
 - Como DMZ, puede admitir conexiones **desde** ciertas subredes de la intranet
 - Despliegue, configuración de webs... (**pero no al revés**)
 - Los portales de administración (Ej.: **/admin**) **no deben estar expuestos al público**
 - La **DMZ privada**, con **solo el back-end de las aplicaciones**
 - **Nunca está expuesta al público**
 - El front de cada aplicación **solo se comunica con su backend asociado**
 - Garantizado con las **reglas de forwarding** de los firewalls vistas
 - Como DMZ, puede admitir conexiones **desde** (no al revés) ciertas subredes de la intranet
 - Despliegues, desarrollo...



SECURE NETWORK INFRASTRUCTURE (SNI): ZONAS

- **La Intranet**, donde están los empleados segregados en distintas subredes
 - **Normalmente por su rol**: Desarrollo, pruebas, despliegue, contabilidad....
 - Con énfasis en **qué subredes pueden ver a qué otras** (firewalls internos)
 - **La intranet segura**, donde residen los **datos más críticos de la empresa**
 - Qué datos son lo determina su política de seguridad (**Tema 3**)
 - Los accesos a ella deben estar **muy restringidos y planificados**
 - **Red de administración / control**: Supervisión, monitorización y vigilancia de todas las demás redes (Ex.: Wazuh, **Tema 3**)
- **Quién ve a quién, qué conexiones se permiten y cuáles no, qué datos son accesibles a qué personas...debe planificarse antes**



RANGOS DE IPs Y DIRECCIONAMIENTO DE REDES



- Cada red/subred de la SNI **debe usar una máscara CIDR de subred diferente**
 - E IPs privadas (https://es.wikipedia.org/wiki/Red_privada)
- **¿Cómo? Usa firewalls híbridos/hardware con varias tarjetas de red y DHCP**
 - Asigna sus NICs a **zonas**, y que el firewall sea el único “puente” entre ellas (**firewall perimetral**)
 - Cada zona **debe tener su propia subred IP, no usada por ninguna otra subred**. Ej.:
 - La subred **10.0.0.0/8** se usa en la Intranet
 - La **192.168.0.0/16** se usa en la LAN de administración
 - Las DMZ y la LAN segura pueden usar subredes **172.16-31.0.0/12**
 - Por supuesto, con **una subred diferente** para la DMZ publica, la privada y la LAN segura (3 subredes)
- **¿Cuántos de ellos pueden hacer uso interactivo de Internet? Los menos posibles**
 - Entonces puedes plantearte tener tu propio DNS seguro aislado (Ej.: PiHole)

POLÍTICA DE PUERTOS Y SERVICIOS

- Fijadas las IPs, hay que establecer una política de ubicación de servicios en puertos
 - El puerto predeterminado para HTTPS (**tcp/443**) sólo se usa en la DMZ pública *¿Motivo?*
- Las demás conexiones a servicios “dentro” de la infraestructura usan puertos TCP y UDP no estándar
 - Aconsejable uno muy alto (30000+)
 - *¿Por qué crees que se hace esto?*
 - **Todos los puertos que no se usen deben estar cerrados**

```
Nmap scan report for ccc-d09-macc242.net.newport.ac.uk (10.208.42.13)
Host is up, received arp-response (0.00070s latency).
Not shown: 976 closed ports, 1 filtered port
Reason: 976 resets and 1 no-response
PORT      STATE SERVICE      REASON    VERSION
135/tcp    open  msrpc        syn-ack    Microsoft Windows RPC
139/tcp    open  netbios-ssn  syn-ack
445/tcp    open  netbios-ssn  syn-ack
1025/tcp   open  msrpc        syn-ack    Microsoft Windows RPC
1026/tcp   open  msrpc        syn-ack    Microsoft Windows RPC
1027/tcp   open  msrpc        syn-ack    Microsoft Windows RPC
1028/tcp   open  msrpc        syn-ack    Microsoft Windows RPC
1216/tcp   open  ssl/sophos   syn-ack    Sophos Message Router
1218/tcp   open  msrpc        syn-ack    Microsoft Windows RPC
1247/tcp   open  msrpc        syn-ack    Microsoft Windows RPC
1801/tcp   open  msmq?        syn-ack
1947/tcp   open  http         syn-ack    Aladdin HASP license manager 12.47
2103/tcp   open  msrpc        syn-ack    Microsoft Windows RPC
2105/tcp   open  msrpc        syn-ack    Microsoft Windows RPC
2107/tcp   open  msrpc        syn-ack    Microsoft Windows RPC
8192/tcp   open  sophos       syn-ack    Sophos Message Router (Interoper$
8193/tcp   open  tcpwrapped   syn-ack
8194/tcp   open  ssl/sophos   syn-ack    Sophos Message Router
9535/tcp   open  man?         syn-ack
9593/tcp   open  ssl/http     syn-ack    LANDesk/Intel Management Agent ht$
9594/tcp   open  ssl/http     syn-ack    LANDesk/Intel Management Agent ht$
9595/tcp   open  http The qui syn-ack    LANDesk/Intel Management Agent ht$
33354/tcp  open  landesk      syn-ack    LANDesk Management Suite (Targete$
1 service unrecognized despite returning data. If you know the servic$
SF-Port9535-TCP:V=6.46I=7%D=6/2%Time=538C7940%P=x86_64-unknown-linux$
```

No solo hay que tener cuidado con lo que expones, sino con dónde lo expones en cada red.

Fuente:

<https://suprafortix.wordpress.com/2014/05/31/nmap-output-formatting/>

EJEMPLO DE POLÍTICA DE AISLAMIENTO CON FIREWALLS

- Para eso, la configuración de las reglas de los **firewalls** que uses es crítica
 - Aplicando (de nuevo) el **principio de minimización** visto
- El **firewall de la red DMZ pública...**
 - Solo permitiría **el tráfico TCP 443 entrante** (u otros servicios si son imprescindibles)
 - Por ejemplo, **VPNs** para que accedan los empleados (siguiente sección)
 - Recuerda que no debes preocuparte de la respuesta a estas conexiones gracias a los **firewalls SPI**
 - El **reverse proxy oculta al público completamente la arquitectura de red** “al otro lado”
 - Por lo que probablemente es la única máquina / clúster sobre el que este **firewall** debe actuar
 - Podría también controlar las conexiones salientes de la infraestructura “hacia afuera”
 - **El tráfico saliente** (recuerda: **NO es la respuesta al entrante**) debe restringirse todo lo posible
 - Las conexiones iniciadas por servidores en la DMZ pública hacia Internet deben limitarse a los servicios imprescindibles (**principio de minimización**)
 - Por ejemplo, limitarlas a los protocolos / IPs / dominios **usados por las actualizaciones**

POLÍTICA DE AISLAMIENTO CON FIREWALLS

- **Entre la DMZ pública y la DMZ privada...**
 - Hay un firewall haciendo forwarding como **único “punto de paso”**
 - *¿Qué garantiza?*
 - Las reglas del firewall permiten forwarding con la fórmula vista en el **Nivel 2** *¿Qué garantizaba?*
- **Entre la DMZ privada y la LAN interna...**
 - En la LAN interna puede haber desarrolladores, administradores, etc. (distintos **roles**)
 - Y conviene que cada rol tenga su **subred/zona separada**
 - Con una configuración segura en cada equipo de usuario (**Tema 3**)
 - Misma política de forwarding vista con redes adyacentes
- **Entre la LAN interna y la LAN segura...**
 - Sólo deben estar abiertos los puertos necesarios para acceder a los servidores SGBD cifrados
 - El firewall admite forwarding **restringido a las IP permitidas de ciertas subredes de la LAN interna** (planificadas de antemano, política de seguridad (**Tema 3**))
 - **Máxima restricción:** Ten en cuenta que **estos son tus datos más críticos**

¿CREEES QUE LO HAS ENTENDIDO TODO? ¡AUTOEVALÚATE!



● Asegúrate de haber entendido lo siguiente

- *La principal utilidad de separar tráfico en distintas VLANs*
- *El concepto de NFGW y de UTM, sus funcionalidades, diferencias y similitudes teóricas*
 - *Y que en la práctica la diferencia entre ambos tipos de productos es cada vez menor*
- *Que para planificar una infraestructura altamente segura necesitas un estudio detallado previo de cómo vas a colocar tus defensas*
- *Que el aislamiento entre zonas debe complementarse con un aislamiento entre subredes dentro de una misma zona, para lo cual los firewalls son críticos también*
- *Que cuando tienes que guardar datos críticos necesitas una planificación cuidadosa y detallada de cómo vas a guardarlos y manejarlos*

< Ir al Índice



ACCESO REMOTO A INFRAESTRUCTURAS

Lidiando con las necesidades del teletrabajo



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

¿QUÉ VAS A APRENDER EN ESTE BLOQUE?

- **Ahora que ya hemos visto infraestructuras de 3 niveles de complejidad nos queda planificar cómo acceder remotamente y de manera segura a ellas**
 - Que una infraestructura segmentada no tiene sentido sin un **acceso remoto a la misma también segmentado**
 - Que **usar VPNs** es la forma correcta de usar servicios en remoto
 - Servicios que nunca debemos exponer públicamente si no es estrictamente necesario
 - Y que, por ello, externamente cualquier infraestructura **solo debe exponer su servidor VPN** al que conectarse y los servicios que están destinados al público general (Ej.: web)
 - La diferencia, ventajas y desventajas de **las VPN tradicionales y las P2P**
 - Junto con la capacidad innata de las redes P2P de **crear subredes aisladas** como una ventaja crítica a la hora de gestionara accesos remotos



ACCESO A LAS SUBREDES DE LA INFRAESTRUCTURA



- **Una infraestructura segmentada requiere un acceso de los usuarios segmentado**
 - Debe planificarse con una **política de seguridad (Tema 4)**
- **Aunque depende de cada negocio y el presupuesto, en el bloque anterior vimos**
 - Que en la Intranet debería haber **subredes distintas y aisladas** por firewalls para cada rol de usuario
 - Ejs.: Pruebas, aceptación, despliegue, oficina, nóminas...
 - Que hay que definir **cuáles** de esos roles pueden acceder a otras partes de la red
 - Como la red **DMZ privada** (back) y a la **pública** (front)
- **Hablaremos ahora de los accesos remotos (Ej.: teletrabajo)**
 - Pero **sólo a partes de la infraestructura concretas y autorizadas**
 - Ej.: Subredes de la intranet según el rol del usuario
 - Esto es aplicable a cualquier nivel visto, pero sobre todo en los **Niveles 2 y 3**

INBOUND TRAFFIC FILTERING (D3-ITF) DEL MITRE D3FEND



- El acceso remoto a las partes de la infraestructura debe hacerse **vía VPN**
 - Una vez dentro de la red, los firewalls determinan qué tráfico está permitido y cuál no
 - Para el acceso interactivo a máquinas **en intranets**, debe usarse **SSH** (o soluciones cifradas)
 - **Protegidos adecuadamente**. Ej.: Acceso con certificados / **2FA**, Fail2Ban (contra fuerza bruta)
 - **Jamás exponer servicios de Escritorio Remoto** (RDP) a potenciales amenazas
- Debe emplearse la **ocultación de servicios** a clientes no autorizados
 - Servicios que están funcionando en una máquina, pero **cualquier intento de acceso / escaneo falla**
 - Solo puede contactarse con ellos desde una IP concreta si se conoce la forma de “desbloquearlos”
 - También debería **prohibirse cualquier intento de escaneo** (Ej.: PortSentry)
 - Si queremos **abrir o cerrar servicios concretos a voluntad para IPs concretas**, podemos implementar
 - **Port knocking**: Enviar una secuencia de conexiones a puertos para abrir / cerrar un servicio
 - La información no va cifrada, por lo que **es interceptable y reproducible** (replay attack)
 - **Single Packet Authorization**: Enviar un único paquete cifrado para abrir un servicio
 - La información va cifrada y es muy difícil de vulnerar, con programas como Fwknop



D3-ITF: INBOUND TRAFFIC FILTERING Y D3-ET. ENCRYPTED TUNNELS: VPNs



- **Conectarse mediante VPN a una red implica que tu equipo y esa red se comunicarán por un canal seguro a través de Internet**
 - Es una “línea privada” de acceso, que puede venir con más servicios integrados
 - Aunque la información se transmita vía Internet, **nadie podrá ver o cambiar** lo que envías / recibes
- **Además, tu máquina será como una máquina más de la red de destino**
 - Aunque no esté en el mismo lugar físico, **formará parte de la red a la que se conecta**
 - Es decir, tendrá una IP válida en esa red una vez conectado a la misma
 - Si es una LAN, podrás acceder a otros equipos con los medios pensados para ello
- **Es la forma más segura de conectarte a un sitio remoto**
 - Teletrabajo, laboratorios, tu despacho...
 - **Nunca expongas tus servicios públicamente**, salvo que sea estrictamente necesario
 - Idealmente, se exponen solamente webs públicas y servicios VPN para conectarse a la infraestructura

VPNs “TRADICIONALES”

- En ellas nos conectamos a un **servidor VPN central** de un proveedor
 - Que en este caso está en la infraestructura
 - Desde él **luego nos conectamos a nuestros equipos remotos**
- Obtendremos una IP en un rango asignado por el servidor VPN de la empresa
 - Se suele obligar a que muchos servicios “internos” solo sean accesibles **desde una IP de ese rango**
 - Para tener una IP válida, o estamos dentro de la organización...o nos conectamos vía VPN
 - Mucho más seguro que abrir el servicio a todo Internet



VPN

- De tu casa al servidor VPN nadie podrá ver lo que envías
- Cualquier sitio de Internet con el que contactes verá al servidor VPN, no a ti

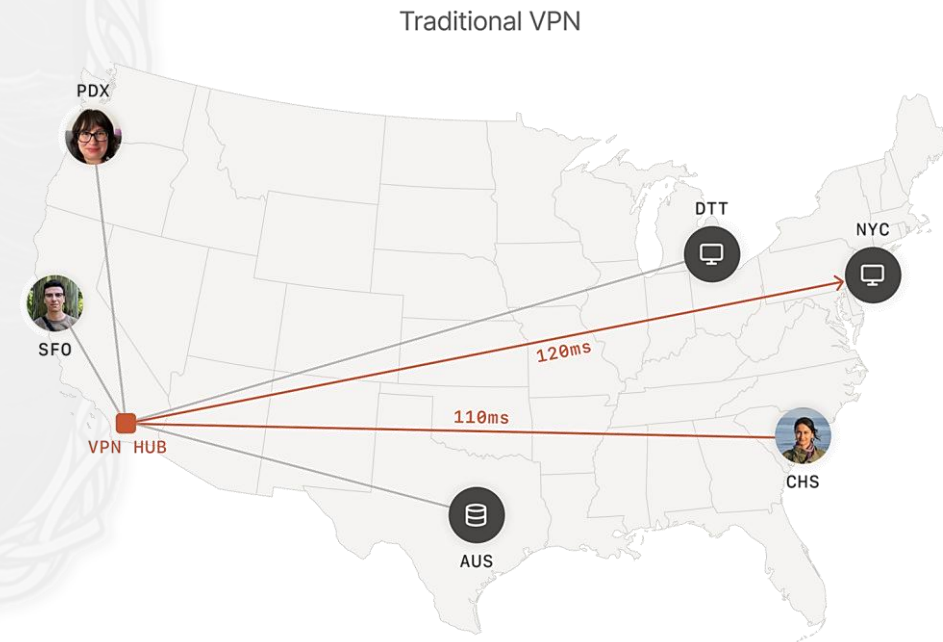
VPNs ENTRE IGUALES/ PEER TO PEER (P2P)

● Una VPN “tradicional” tiene desventajas

- Si el servidor de VPN al que nos conectamos está lejos del equipo remoto, **la conexión puede ser lenta** / con latencia
- Si el servidor central falla, también lo hace la conexión
- Si el servidor de VPN es nuestro, debemos saber instalarlo, configurarlo...
- Y si es un servidor VPN de un proveedor de terceros...**podría espiar** nuestro tráfico o conexiones
 - Ej.: Si se ve comprometido, supply-chain attack...

● Sigue siendo un modelo seguro, pero no siempre lo más adecuado a todos los casos

- ¡Las VPN P2P pueden ser una alternativa mejor!



VPN “tradicional”. Fuente: <https://tailscale.com/>

VPNs ENTRE IGUALES/ PEER TO PEER (P2P)

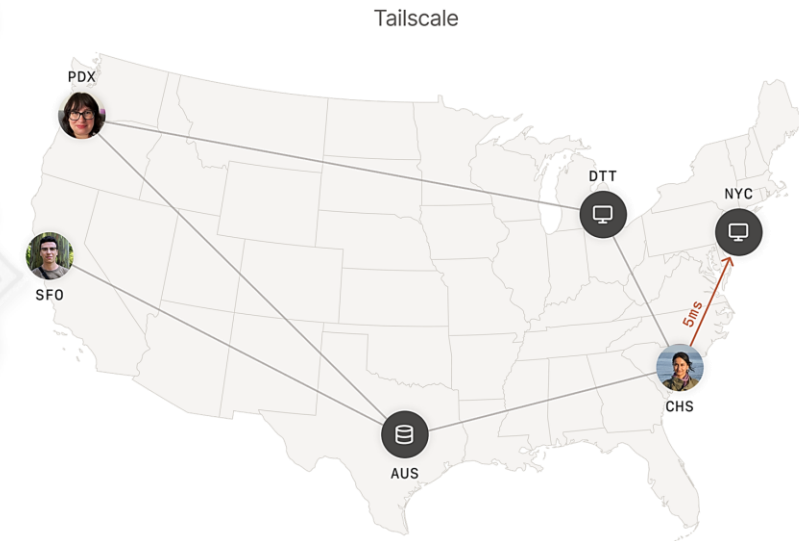


● Servicios VPN que conectan dispositivos remotos P2P

- El acceso seguro a los mismos es posible desde cualquier parte
- Pero la conexión se hará **formando una red peer to peer** entre los dispositivos remotos
 - Todos los dispositivos, sin importar dónde estén, **se verán como parte de una red** (con IPs encajando con la misma máscara CIDR)
 - Configuran la red automáticamente, ocupándose de configurar **firewalls, DNS y routers** automáticamente
 - Incluyendo “saltos” entre redes de distinta clase (Wifi, datos...)
- Ejs.: ZeroTier (<https://www.zerotier.com/>), NetBird (<https://netbird.io/>) o TailScale (<https://tailscale.com/>)

● El futuro tiende a modelos de acceso remoto Zero-Trust Network Access (ZTNA) contratados en nube

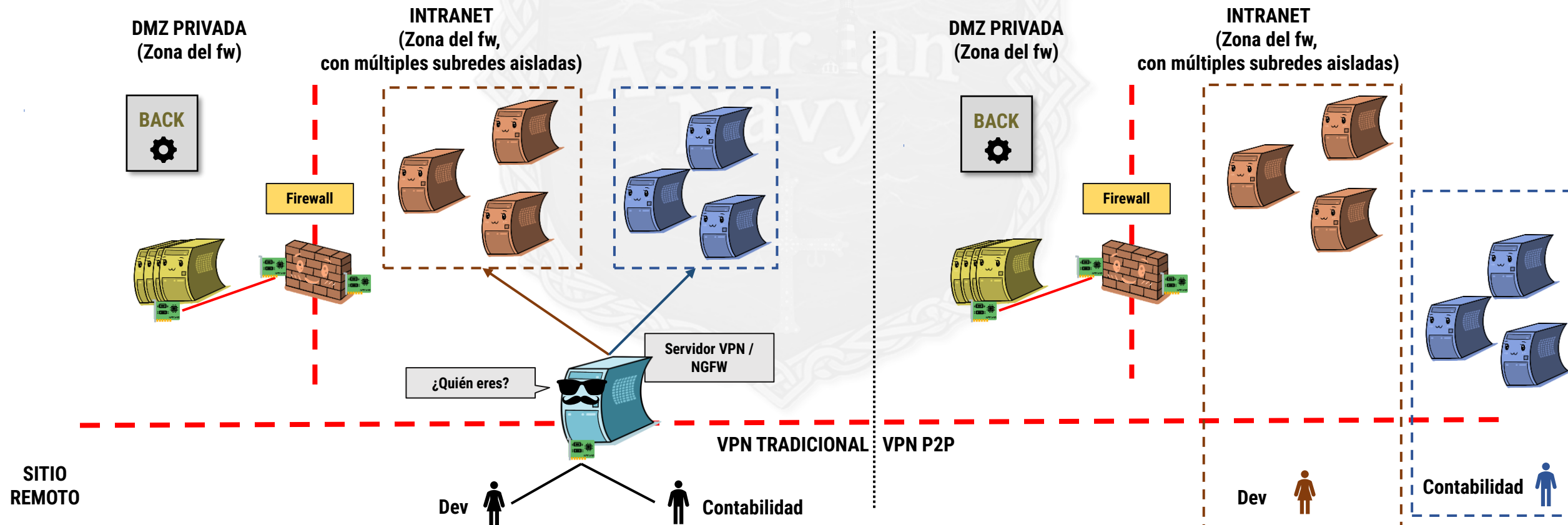
- Introduciendo variables como dispositivo de acceso, lugar, hora...para decidir si se concede el acceso
- Gracias a las características de determinados **firewalls NGFW**



VPN punto a punto TailScale. Fuente:
<https://tailscale.com/>

¿CUÁL USAR? TIENES QUE DECIDIR...

- Con una VPN tradicional debes poner en marcha una serie de reglas que digan a qué máquinas puede acceder un usuario remoto
- Con una P2P puedes crear subredes directamente para los usuarios remotos que pertenezcan a distintos roles (y conexiones entre ellas)



¿CREEES QUE LO HAS ENTENDIDO TODO? ¡AUTOEVALÚATE!



● Asegúrate de haber entendido lo siguiente

- *El acceso remoto a cualquier infraestructura debe hacerse vía VPN*
- *Dicho acceso remoto debe estar restringido solo a usuarios autorizados (y quizá desde lugares, dispositivos, horas...autorizados también)*
- *Que, una vez concedido el acceso, el usuario solo debe poder usar los mínimos recursos posibles para realizar su trabajo*
- *Y que para ello se debe implementar una política estricta de subredes (VPN tradicional) o bien asignar usuarios a subredes aisladas diferentes donde estén sus recursos (VPN P2P)*
- *Que, fuera de la VPN, solo deben estar públicos los servicios imprescindibles para el acceso remoto y para los clientes*
- *Que existen otras técnicas complementarias de bajo nivel para ocultar servicios, proteger de escaneos, fuerza bruta, etc.*



TEMA 5

SEGURIDAD PERIMETRAL Y DE RED



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo